



slington college
(इरिलिङ्टन कलेज)

Module Code & Module Title

CC5009NI Cyber Security in Computing

Assessment Weightage & Type

60% Group Coursework 02

Year and Semester

2024 -25 Autumn Semester

Student Name: Krish Shrestha London Met ID: 23047364

Student Name: Manita Basnet London Met ID: 23047441

Student Name: Nirjal Pandey London Met ID: 23047518

Student Name: Sulav Pathak London Met ID: 23047360

Assignment Due Date: Monday, 12 May 2025

Assignment Submission Date: Sunday, 11 May 2025

Word Count: 6666

I confirm that I understand my coursework needs to be submitted online via MST under the relevant module page before the deadline for my assignment to be accepted and marked. I am fully aware that late submissions will be treated as non-submission and a mark of zero will be awarded.

23047364.KrishShrestha_turitin.docx

Islington College,Nepal

Document Details

Submission ID
trn:oid::3618:95343300

Submission Date
May 11, 2025, 7:23 PM GMT+5:45

Download Date
May 11, 2025, 7:25 PM GMT+5:45

File Name
23047364.KrishShrestha_turitin.docx

File Size
44.6 KB

62 Pages

6,665 Words

38,462 Characters



16% Overall Similarity

The combined total of all matches, including overlapping sources, for each database.

Match Groups

- 76 Not Cited or Quoted 11%**
Matches with neither in-text citation nor quotation marks
- 23 Missing Quotations 4%**
Matches that are still very similar to source material
- 1 Missing Citation 0%**
Matches that have quotation marks, but no in-text citation
- 1 Cited and Quoted 0%**
Matches with in-text citation present, but no quotation marks

Top Sources

- 8% Internet sources
- 4% Publications
- 13% Submitted works (Student Papers)

Integrity Flags

0 Integrity Flags for Review

Our system's algorithms look deeply at a document for any inconsistencies that

Acknowledgements

We want to express our heartfelt gratitude to Mr. Sugam Giri Sir, our tutor, and Mr. Samrid Budathoki Sir, our lecturer, for their constant support and guidance throughout the coursework. Their valuable feedback, encouragement, and thorough evaluation played a crucial role in helping us refine our attack demonstration and ensure that our mitigation strategies were effective and well-executed.

We are also sincerely thankful to Ganesh Subedi Sir and Prashant Pudasaini Sir for granting us access to the college's Layer 2 switch. Their support enabled us to explore and test the mitigation techniques against ARP spoofing in a real network environment.

Their contributions have been vital to the success of this project, and we deeply appreciate their time and efforts.

Abstract

This report investigates the working mechanics and consequences of Man-in-the-Middle (MitM) attacks facilitated through Address Resolution Protocol(ARP) spoofing. ARP spoofing enables an attacker to link their MAC address to the IP address of another device, such as the default gateway, taking advantage of the system's inherent trustworthiness. This misleads network devices into transferring data meant for the legal device to the attacker.

This report provides a comprehensive analysis of ARP Spoofing and illustrates through a practical demonstration using Ettercap, Bettercap, and Wireshark, how an attacker can position themselves between two communicating devices. In response to the identified vulnerabilities, the report evaluates various mitigation strategies aimed at preventing or minimizing the impact of ARP Spoofing attacks. This demonstration underscores the ease with which such attacks can be conducted, highlighting the critical need for robust network security measures.

Table of Contents

Acknowledgements.....	i
Abstract.....	ii
Table of Figures	iv
Table of Tables	v
1. Introduction.....	1
1.1 Aim and Objectives.....	3
1.2 Technical terminologies.....	4
1.3 Report Structure	6
2. Background.....	7
2.1. Working mechanism of ARP	8
2.2. ARP Spoofing	9
2.3. Tools Used in ARP Spoofing.....	12
2.4. Past breaches using ARP Spoofing.....	13
3. Demonstration.....	14
3.1.First Attack.....	15
3.2. Second Attack	29
4. Mitigation.....	42
5. Evaluation	47
6. Conclusion	52
7. References.....	53
8. Appendix.....	57

Table of Figures

Figure 1 : ARP (Lake, 2023).....	1
Figure 2 ARP packet format (ipcisco, 2024)	7
Figure 3 Working of ARP (elprocus, 2024).....	8
Figure 4 ARP poisoning (rfwireless, 2024)	9
Figure 5 Eavesdropping attack (Geeksforgeeks, 2024)	10
Figure 6 MitM attack (imperva, 2025)	11
Figure 7: ARP flooding (sentinelone, 2024).....	11
Figure 8: Output of “net.show” Command.	18
Figure 9: Enumerated local devices after subnet.	19
Figure 10: Setting ARP Spoofing Targets.	19
Figure 11: Sending forged ARP replies to the targets.	20
Figure 12: Display of Forged ARP replies being sent to targets.	20
Figure 13:ARP Table on victim machine.	21
Figure 14: Enabling IP Forward.	22
Figure 15: Starting network traffic sniffing.	23
Figure 16: Launching Metasploitable2 as the Target Vulnerable Web Application	24
Figure 17: Attempting login with Multiple Credentials (TEST 1).	25
Figure 18: Attempting login with Multiple Credentials (TEST 2).	25
Figure 19: Capture of incorrect login credentials.	26
Figure 20: Successful capture of correct login credentials.	27
Figure 21: ARP Spoofing Attack Lab Setup.....	32
Figure 22: Ettercap configuration	33
Figure 23: Ettercap Host List.....	34
Figure 24: Ettercap Target Selection	35
Figure 25: Ettercap Configuration for ARP Poisoning.....	36
Figure 26: Wireshark Capture Showing ARP Spoofing Traffic.....	37
Figure 27: Spoofed Gateway MAC on Window 7.....	38
Figure 28: Spoofed Target MAC on Router	38
Figure 29: Telnet Session to Router R1.....	39
Figure 30: Wireshark Capturing Telnet Password in Cleartext.....	40
Figure 31: ARP Table Showing IP Addresses.....	43
Figure 32:Adding a Permanent ARP Entry	44
Figure 33 Anti ARP spoofing commands.....	45

Table of Tables

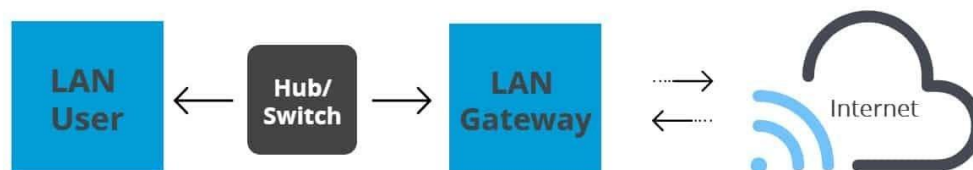
Table 1 Technical Terminologies.	4
Table 2 Report Structure	6
Table 3 Risk Assessment Table for First Attack	28
Table 4 Risk Assessment Table for Second Attack	41
Table 5 Comparative table.	46

1. Introduction

In today's digital environments, Cybersecurity has grown into a major concern for individuals, governments, and businesses. The possibility of cyberattacks rises along with the complexity of networks and the number of linked devices. These threats might appear in various forms, and they are Malware, phishing, botnets, worms, viruses, DDoS attacks, blended threats, SQL injection attacks, and MITM. In LANs, ARP spoofing is one of the serious threats. (Miller, 2025)

ARP poisoning, which is also known as ARP spoofing, is one of the types of Man-In-The-Middle Attacks (MITM) in which an attacker transmits deceptive ARP packets to associate their MAC address with the IP address of another networked device. In this scenario, the victims believe that they are interacting with each other, but in fact, the attacker controls the connection, which means a third party is in place to supervise communication between the client and server. Once the attacker successfully modified ARP tables, the attacker now has complete access to the data stream, where an attacker can modify intercepted data, inject malicious payloads, and relay tainted packets to disrupt network services (sentinelone, 2024).

Routing under normal operation



Routing subject to ARP cache poisoning

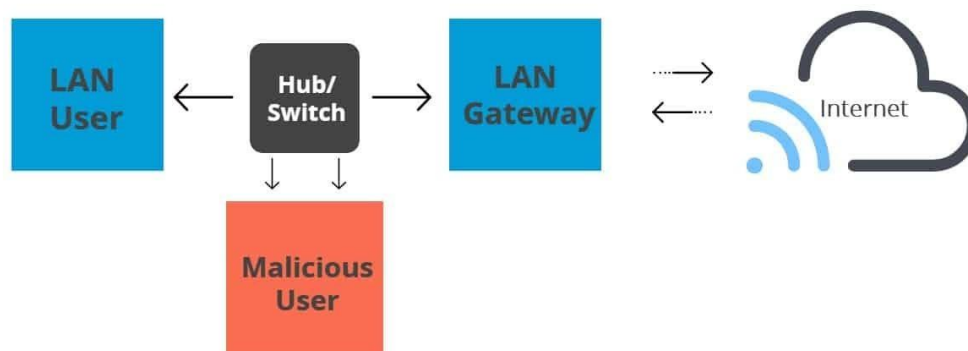


Figure 1 : ARP (Lake, 2023)

ARP, as a part of the Internet protocol suite, was defined in 1982 by RFC 826 (Plummer, 2025). ARP was designed in an era when scientists and network engineers were optimizing for functionality over security. Therefore, ARP lacked mechanisms for authenticating ARP responses. This oversight paved the way for spoofing techniques that exploit the lack of authentication protocols (Genians, 2023).

ARP spoofing (cache poisoning) emerged in the 1980s when hackers exploited ARP's trust-based design by transmitting falsified ARP messages. This created incorrect associations between IP and MAC addresses, allowing attackers to redirect network traffic through their machines (CVE Details, 1999), facilitating Man-in-the-Middle (MITM) and Denial of Service (DoS) attacks.

Notable ARP-Related Attacks

- 2010 Stuxnet Worm: This sophisticated attack incorporated ARP spoofing techniques as part of its strategy, targeting Iran's nuclear infrastructure (GoDaddy Content Team, 2024).
- 2008 Metasploit Incident: Attackers compromised a server within Metasploit's hosting provider's network, employing ARP poisoning to redirect website visitors to a defaced page, though the Metasploit servers themselves remained secure (Jongsma, 2008).
- The development of tools such as Arpspoof, Ettercap, and Arpoison automated these attacks by simplifying the process of sending forged ARP messages (Ettercap Project, 2001); (Landau, 1990s).

Defensive Countermeasures

The 1990s and early 2000s witnessed the development of defensive measures to mitigate ARP spoofing risks:

- Implementation of static ARP entries (though impractical for larger networks).
- Switches with built in Dynamic ARP Inspection (DAI).
- Monitoring solutions such as Arpwatch.

Current Security Implications

Despite these countermeasures, ARP's fundamental security issues remain relevant (Indusface, 2025) due to:

- Hybrid network implementations
- Proliferation of IoT devices
- Backward-compatible infrastructure and software
- Continued extensive use of IPv4 in Small Office/Home Office (SOHO) local area networks.

1.1 Aim and Objectives

- **Aim:**

The main aim of this paper is to use ARP spoofing to demonstrate and investigate a Man-in-the-Middle attack, underscoring its effects on network security and examine mitigation strategies to protect against such attacks.

- **Objectives:**

The key objective of this report is:

- To investigate the concepts behind Man-in-the-Middle (MitM) attacks and ARP spoofing, and to understand ARP's critical role in enabling communication between devices on a local network.
- To demonstrate how ARP spoofing attacks are carried out using tools such as Bettercap and Ettercap, highlighting how attackers can exploit ARP for malicious purposes.
- To analyse the potential impact of ARP spoofing on network security, including risks such as data interception, session hijacking, and denial of service.
- To research and evaluate various mitigation techniques against ARP spoofing, focusing on both prevention and detection strategies used to secure network environments.

1.2 Technical terminologies

The technical terminologies used in this report are:

Table 1 Technical Terminologies.

S.N.	Terminology	Description
1.	Address Resolution Protocol (ARP)	On a local network, Address Resolution protocol is used to map an IP address to its appropriate MAC address.
2.	Media Access Control (MAC) Address	MAC address is a unique identifier given to a NIC that facilitates local network connectivity.
3.	Internet Protocol (IP) address	IP address is a unique numerical identifier that is given to network-connected devices to identify and locate them.
4.	ARP Spoofing	An attack occurs when a malicious actor uses a LAN to deliver forged ARP packets.
5.	Default gateway	It is a path used to transmit information when the device is unsure about the destination.
6.	Man-in-the-middle (MITM) attack	MITM attack is a cyberattack which occurs when an attacker secretly intercepts and transfer messages between two parties that assume they are speaking to one another directly.
7.	Denial of Service (DoS)	DoS attack is an attempt to overwhelm a network or website in an effort to compromise its functionality or render it totally unavailable.
8.	Session hijacking	Session hijacking is when an attacker hijacks a genuine user's session by utilizing session IDs that have been documented, brute-forced or reverse-engineered.
9.	ARP tables	It maps IP addresses to MAC addresses which allows devices to interact on a network by

		resolving the physical addresses of other devices.
10.	Static ARP entries	A permanent entry in your ARP cache.
11.	Network switches	It's a network device that is used to segment the networks into different subnetworks.
12.	Dynamic ARP Inspection (DAI)	It's a security features that protects ARP which is weak to an attack like ARP poisoning.
13.	Arpwatch	It's an open-source computer software program that helps to monitor Ethernet traffic activity on your network and maintains a database of ethernet/Ip address pairings.
14.	Authentication	It's a process of verifying someone's identity and ensuring only authorized users or systems gain access to resources or systems.
15.	Small Office/Home Office (SOHO)	It is a type of business /industry that employs one to a thousand people.
16.	Internet of Things (IoT) Devices	IoT devices are nonstandard computing hardware that can send data and connect wirelessly to a network.

1.3 Report Structure

The structure of this report is as follows:

Table 2 Report Structure

Chapter	Title	Content
1	Introduction	An explanation of ARP, breakdown of how an attacker performs ARP spoofing and exploration on origins of ARP Spoofing and evaluation of attacks.
2	Background	An in-depth investigation of the ARP protocol, its drawbacks, and the various manners in which ARP Spoofing performs in a network environment.
3	Demonstration	An outline of the steps and possible dangers involved in carrying out an ARP Spoofing assault in a controlled environment.
4	Mitigation	Analysis of the many methods and resources available to stop or identify ARP Spoofing attacks, including how well they work.
5	Evaluation	An in-depth examination of the suggested methods for mitigation that covers the advantages, disadvantages, and acceptability for use in actual situations.
6	Conclusion	Key findings are presented in the conclusion, along with suggestions for improving network security against ARP spoofing attacks.

This study aims to give a comprehensive overview of MITM attacks using ARP Spoofing and practical ideas for protecting network infrastructures by methodically examining each of these topics.

2. Background

Address resolution protocol (ARP) is a protocol that connects a dynamic IP address to a fixed physical MAC address (Fortinet, 2025). IP addresses in IPv4 are of 32 bits while MAC addresses are of 48 bits, and to enable communication, ARP maps a 32-bit IPv4 address to its corresponding 48-bit MAC address (Zydyk, 2023). This protocol runs in layer 2 and 3 of the OSI model. The data link layer of the OSI model is where the MAC address exists, while the network layer of the OSI model is where the IP exists, devices must have a unique MAC address to run internet (rfwireless, 2024).

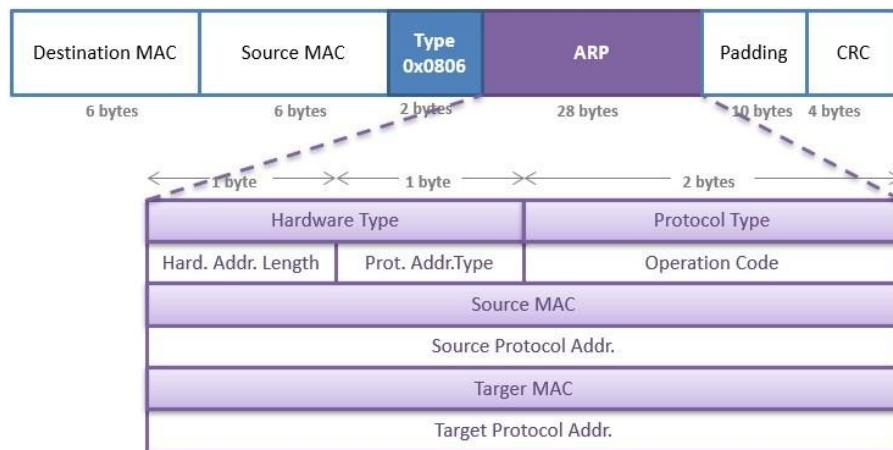


Figure 2 ARP packet format (ipcisco, 2024)

2.1. Working mechanism of ARP

When a source device wants to find the mac address of the destination device in the network layer, it first checks its ARP cache (or ARP table) to see if the destination device's MAC address is already stored. If the MAC address is present, then it uses it from there but if not then an ARP request message is generated by the source device. The packet contains the MAC address and IP address of the source device and only IP address of the destination device because it does not know the MAC address of the destination device. The ARP request will be broadcasted to every device connected to the local network. Each device that receives the ARP request will compare the IP address of the destination with their own IP address. If the IP address of the destination matches with the device's IP address, then an ARP reply message will be sent to the source device, and if it does not match, then the packet will simply be dropped. The device that replies to the ARP Request message will send its MAC address directly (unicast) to the source device. After receiving the ARP reply to the source device, it will update its ARP cache and will now be able to send the packets to the destination (afteracademy, 2020).

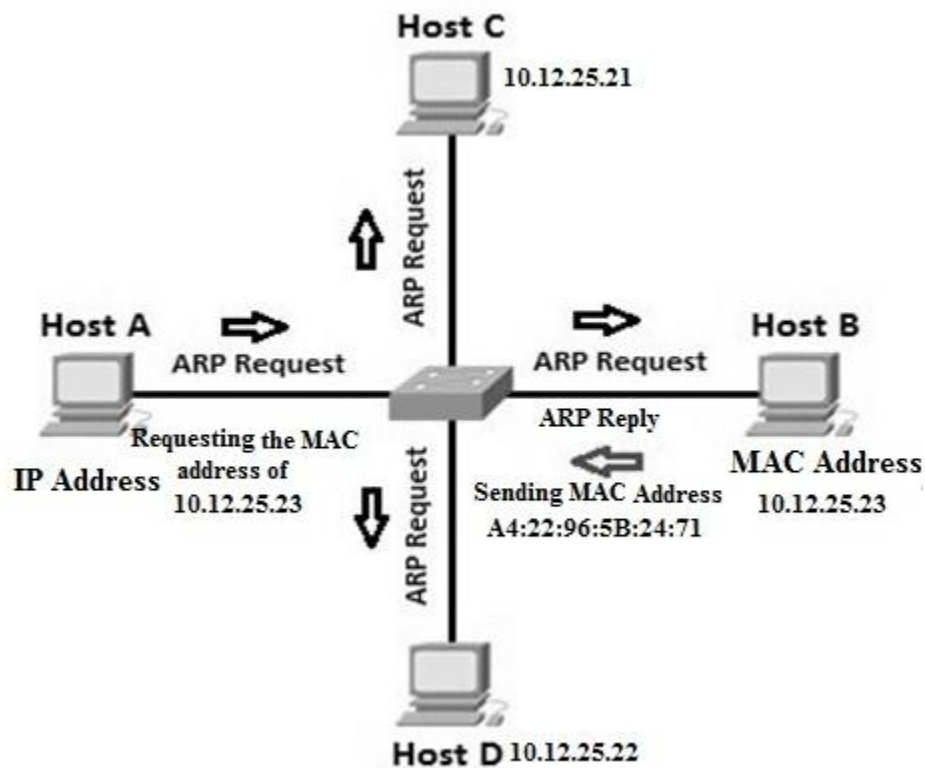


Figure 3 Working of ARP (elprocus, 2024)

2.2. ARP Spoofing

ARP spoofing or ARP poisoning is a Man in the Middle (MitM) attack in which an attacker sends deceptive ARP response on a LAN to connect the attackers MAC address with the IP of a legitimate host device of the network (Hijazi & Obaidat, 2018). It is the process of faking ARP packets to be able to mimic the host of the network. This lack of security measures in ARP protocol allows an attacker to flood the victim with false ARP replies. The attacked user device will store an incorrect MAC address in their ARP table to route their network traffic towards that of an attacker. At this point, an attacker would be able to intercept, modify, or block that traffic which could lead to serious security exploits such as data theft, session hijacking, or denial of service (Ramachandran & Nandi, 2005).

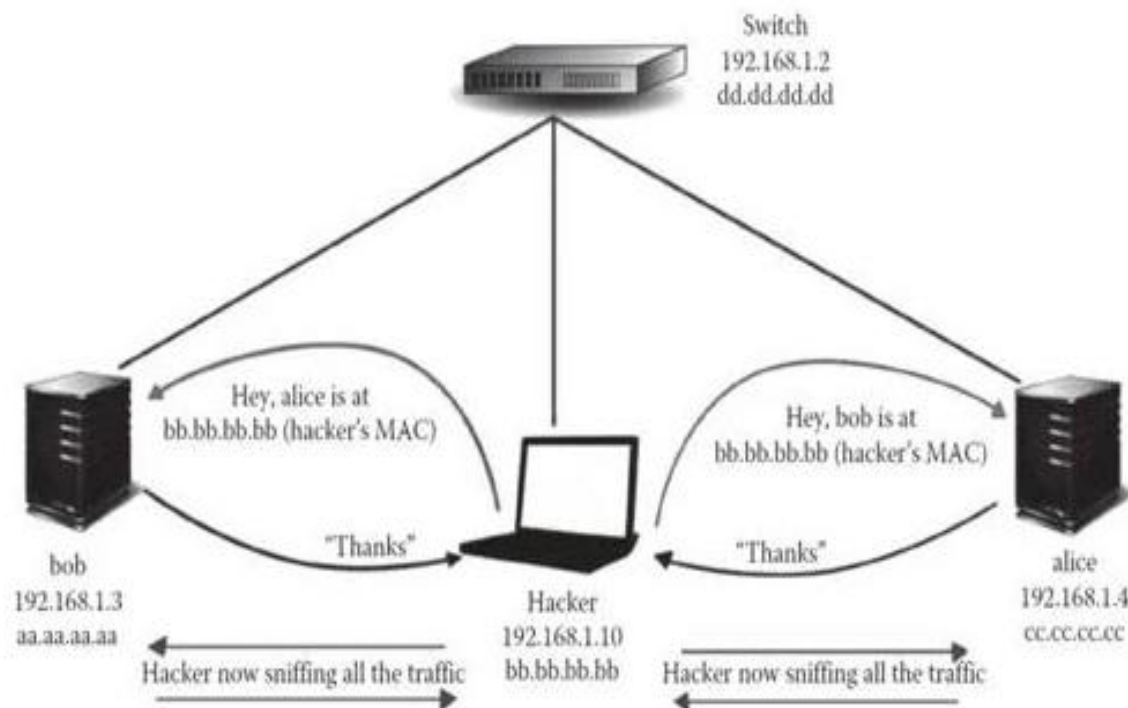


Figure 4 ARP poisoning (rfwireless, 2024)

The base aim of an ARP spoofing attack is to intercept, manipulate, or disrupt the network traffic between devices. Based on this, a thief applies various malicious activities as mentioned below:

Eavesdropping: When attackers carry out an ARP Spoofing attack, they intercept data packets passing over the network. They then gain access to confidential information like login passwords, financial details, and private communications without being detected. This is, without a doubt, the riskiest form of eavesdropping when confidential information can easily be accessed and utilized using an unencrypted network (SentinelOne, 2024).

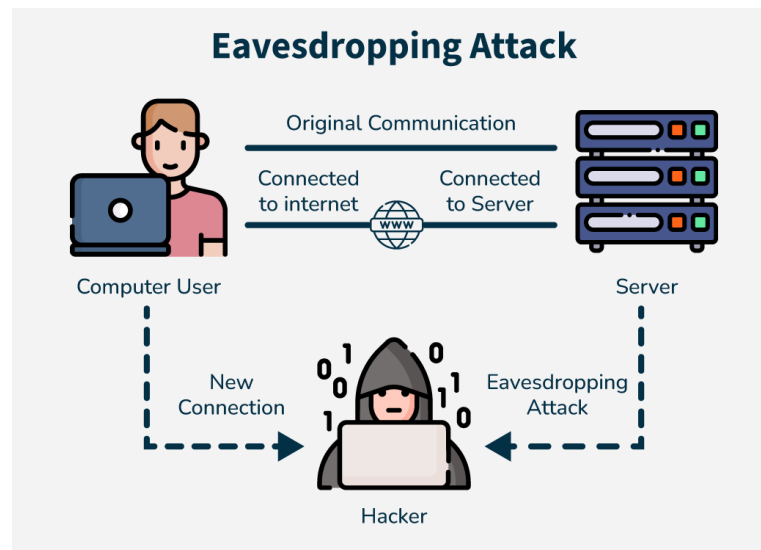


Figure 5 Eavesdropping attack (Geeksforgeeks, 2024)

Man-in-the-Middle (MitM) ARP Spoofing: The attacker positions himself between two devices that are communicating by forging ARP responses. Both devices believe they are communicating directly with each other, allowing the attacker to intercept, modify, or inject malicious data into the communication (Nidecki, 2025)

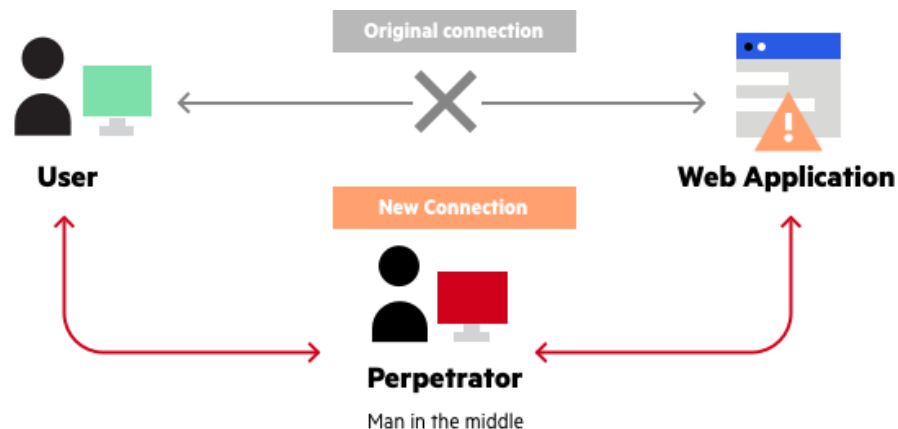


Figure 6 MitM attack (imperva, 2025)

ARP Flooding (Denial of Service): The attacker floods the network with a high volume of spoofed ARP packets that fill the ARP caches of devices. This can lead to legitimate ARP entries being overwritten and a denial of service since devices cannot communicate properly.

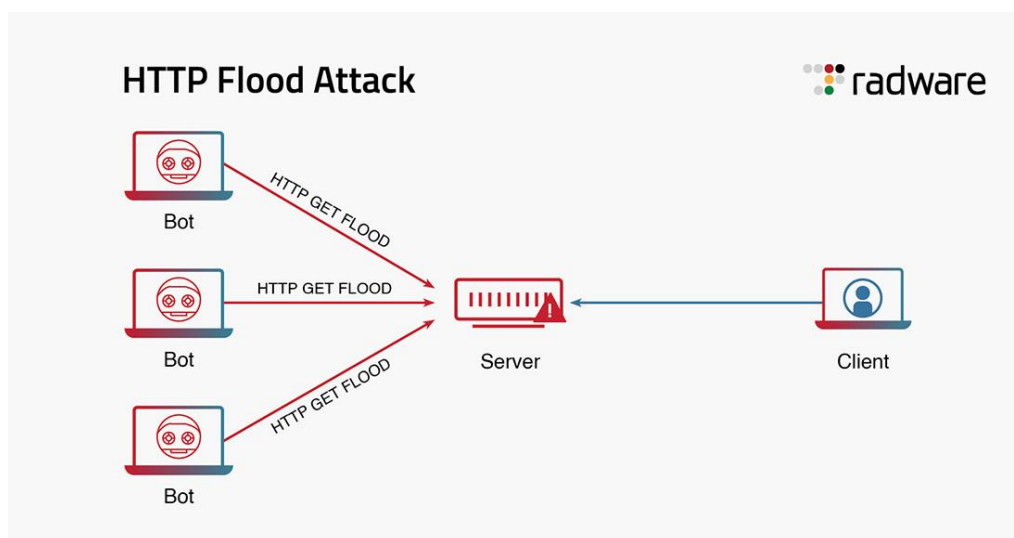


Figure 7: ARP flooding (sentinelone, 2024)

2.3. Tools Used in ARP Spoofing

A comprehensive suite for man-in-the-middle attacks, including ARP poisoning. It allows attackers to intercept, modify, and analyze network traffic.

KickThemOut: A Python-based tool that performs ARP spoofing to kick devices off a network. It is designed for offensive security purposes (Grimmick, 2022).

Larp: Another Python-based tool specifically for ARP poisoning, used in network spoofing and penetration testing (Grimmick, 2022).

Arpspoof: Part of the Dsniff suite, this tool is used to forge ARP replies and redirect traffic to the attacker's machine (Grimmick, 2022).

Cain & Abel: A Windows-based tool that includes ARP poisoning capabilities for intercepting network traffic, among other features (Grimmick, 2022).

Bettercap: A modular, portable tool that supports ARP spoofing and other network attacks, often used for security assessments (Grimmick, 2022).

NetCut: A tool that can perform ARP spoofing to disconnect devices from a network, commonly used in network management and testing (Grimmick, 2022).

2.4. Past breaches using ARP Spoofing

A. Metasploit Incident:

The 2008 Metasploit exploits relate to a major exploitation of a massive hole in the way that Microsoft Windows servers are computer and the Windows systems by its specific MS08-067 vulnerability using the Metasploit Framework. Metasploit, in its early release as an open-source penetration tool, swiftly turned out to be a double-edged sword: it gave power to security experts to learn and bolster a strong shield, while it also gave cyber attackers a capable and uncomplicated mechanism to launch real, adjective cyberattacks (Barath, 2021).

In October 2008, Microsoft disclosed MS08-067 (CVE-2008-4250), a critical flaw in the Windows Server service allowing remote code execution via crafted RPC requests. Its ability to be exploited without user interaction made it ideal for worms and automated attacks. Soon after, Metasploit released a public exploit module, enabling both researchers and attackers to target unpatched Windows systems (Barath, 2021).

Using Metasploit, the attacker easily targeted vulnerable systems like unpatched Windows XP or Server 2003 machines. After identifying targets with a network scan, they selected the MS08-067 exploit, set the target IP (RHOST), chose a payload (e.g., reverse shell), and launched the attack. If successful, they gained remote access, enabling data theft, lateral movement, or malware installation (Thurston, 2008).

The MS08-067 exploit rapidly spread far and wide. Criminals soon exploited the vulnerability to produce infamous malware such as the Conficker worm, which infected millions of computers worldwide. Because exploits existed in Metasploit, it became simple to carry out attacks and exploits rapidly surfaced online. Organizations that didn't implement Microsoft's emergency patch quickly found their networks breached, in some instances just hours after the exploit was published (Threat Intelligence, 2021).

This incident showed how penetration tools like Metasploit can be used for both defense and attack. It marked a shift in cybersecurity, with hackers adopting advanced tools to launch faster, more powerful attacks. The 2008 Metasploit case remains a clear example of how quickly vulnerabilities can be exploited. (Kerner, 2012).

3. Demonstration

In this document, we have demonstrated two ARP poisoning attacks following the Penetration Testing Execution Standard (PTES) methodology to better understand the concept and gravity of the attack. We aligned the attack simultaneously with the PTES model, resulting in a comprehensive and structured approach to ethical hacking. In the first attack, we have compromised the Metaspitable2 server and allowed the attacker to gain the credentials used in the Metaspitable2 by the victim, while in the second attack, we made sure that the attack compromises the entirety of the network, allowing the attacker to gain credentials through any vulnerable services running in the network. We have used multiple tools to attack and to monitor the attack throughout this part, which are explained below:

A. Bettercap

Bettercap is a powerful tool for ARP spoofing and MITM attacks on IPv4 networks. It tricks devices into thinking the attacker is the gateway, allowing traffic interception and manipulation. We used it in our first attack because it offers real-time control, live ARP table updates, and a clean interface for monitoring spoofing status and captured data (Bettercap, 2025).

B. Ettercap

Ettercap is one of the classic tools for Man-in-the-Middle (MITM) attacks and network analysis, especially known for its ARP spoofing capabilities. It's written in C and designed to support real-time traffic interception, packet filtering, and active injection on a LAN (Ettercap, 2025). We have used Ettercap in the second attack as its graphical user interface (GUI) helps us understand what's happening on the network, visualize targets, and manage MITM sessions.

C. Wireshark

Wireshark is a network analyzer that captures and displays the real-time details of network traffic (Hanna, 2024). We have used Wireshark in both attacks to capture the ARP packet and confirm that spoofing was successful by verifying forged ARP replies on the network.

3.1. First Attack.

Phase 1: Pre-Engagement Interactions

Scope of Engagement:

This penetration testing simulation was performed in a controlled virtual lab environment. The local network consisted of:

- Kali Linux (Attacker)
- Windows 7 (Victim)
- Metasploitable2 (Web Server)
- Router (Default Gateway)

The test was limited to the 192.168.125.0/24 subnet.

Objectives:

- Perform ARP spoofing to become a Man-in-the-Middle (MitM).
- Intercept unencrypted HTTP login credentials.
- Evaluate the effectiveness of network-level attacks and identify vulnerabilities.

Rules of Engagement:

- No damage or permanent changes to systems.
- No scanning beyond the defined subnet.
- Simulation is performed under supervision and isolated from real-world networks.

Phase 2: Intelligence Gathering

Target Environment:

- Internal network (192.168.125.0/24).
- Devices:
 - Router (192.168.125.1)
 - Windows 7 host (192.168.125.130)
 - Attacker: Kali Linux
 - Web application host: Metasploitable2 (DVWA)

Passive Reconnaissance:

- Identified live hosts via net.probe and net.show commands in Bettercap.
- Mapped IP and MAC address relationships within the subnet.

Phase 3: Threat Modeling

Targeted Assets:

- Usernames and passwords submitted through HTTP login forms.
- Web server (DVWA) hosted on Metasploitable2.
- Network routing between the victim and the web server.

Threat Actors (Simulated):

- Local attackers gaining unauthorized access to sensitive credentials.

Attack Vector:

- ARP spoofing to perform MitM.
- Sniffing unencrypted HTTP login traffic using Bettercap.

Phase 4: Vulnerability Analysis**Findings:**

- The Windows 7 machine accepted spoofed ARP replies.
- DVWA used HTTP without SSL/TLS encryption.
- The ARP cache on the victim was not protected against poisoning.

Vulnerabilities Exploited:

- Insecure ARP protocol (lack of verification).
- Lack of encrypted communication (HTTP login on DVWA).

Tools Used:

- Bettercap for spoofing and sniffing.
- Native arp -a for validation.
- DVWA for login simulation.

Phase 5: Exploitation

STEP 1: Check devices in the network.

Using Bettercap via Kali Linux, enter the command “net.show” for checking the IP and MAC tables along with their corresponding interface and device name.

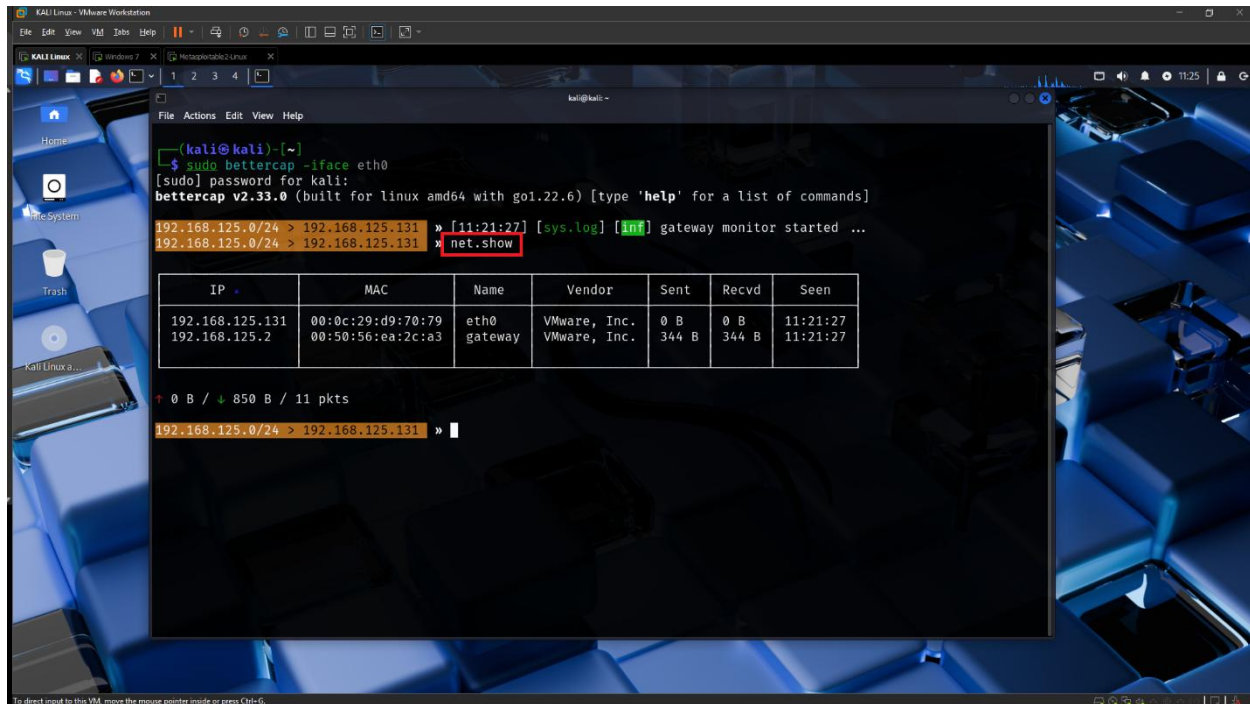


Figure 8: Output of “net.show” Command.

STEP 2: Probe the subnet.

Use the command “net.probe on” to enumerate local devices, then enter “net.show” command to check the IP and MAC tables along with their corresponding interface and device name.

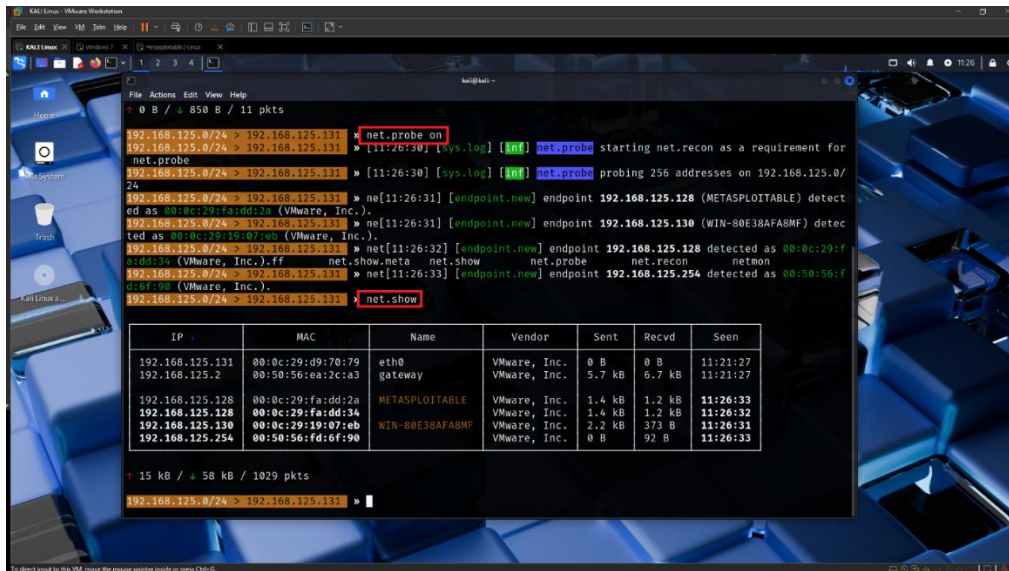


Figure 9: Enumerated local devices after subnet.

STEP 3: Set the ARP targets

Use command “set arp.spoof.targets <router IP>, <Windows 7 IP>” i.e set arp.spoof.targets 192.168.125.1, 192.168.125.130 which will set the targets as Router and Windows 7.

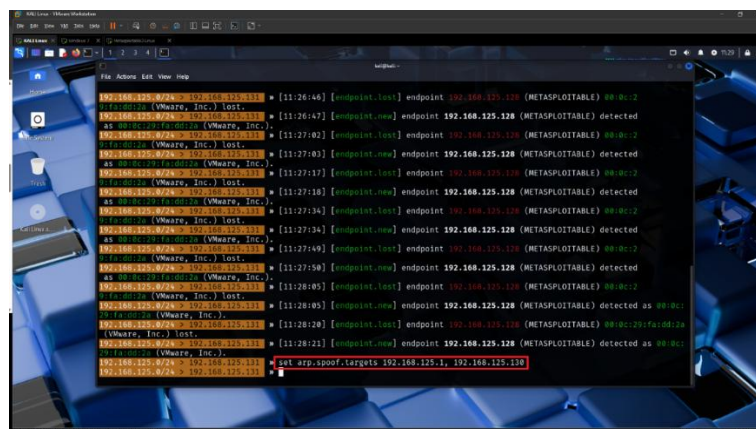


Figure 10: Setting ARP Spoofing Targets.

STEP 4: Sending forged ARP replies to the targets.

Enter the command “arp.spoof on” to send forged ARP replies to both targets, which will poison their ARP cache so both devices believe that your machine’s MAC address is the other one.

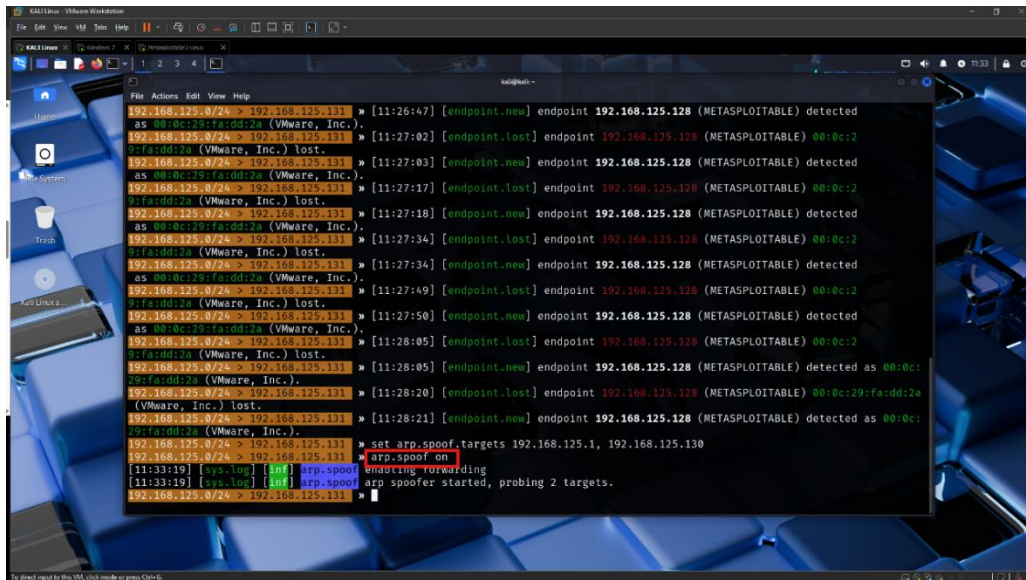


Figure 11: Sending forged ARP replies to the targets.

We can see the forged ARP replies being sent.

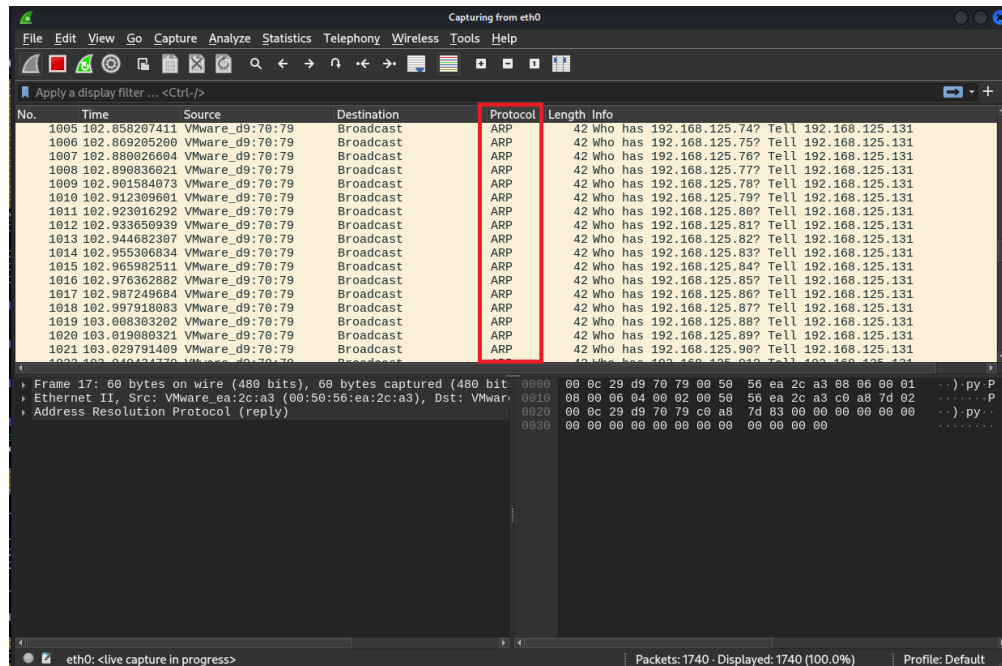


Figure 12: Display of Forged ARP replies being sent to targets.

STEP 5: Checking ARP poisoning in host device.

In the command prompt of the victim machine, run the command “arp -a” to see the ARP table. In this case, we can see the ARP table contains the IP addresses of the gateway and Kali machine, but the MAC address is the same for both because of the ARP poisoning which means our ARP poisoning was successful.

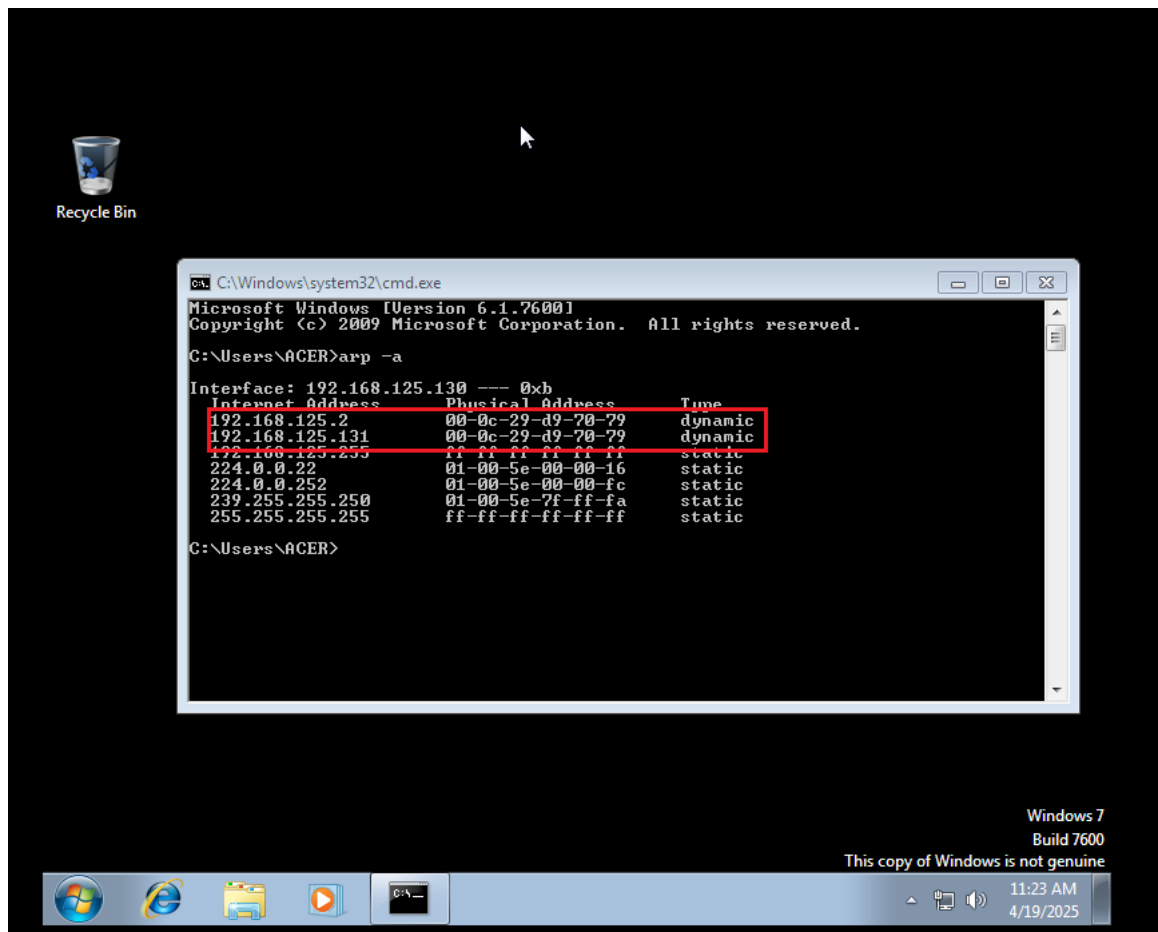
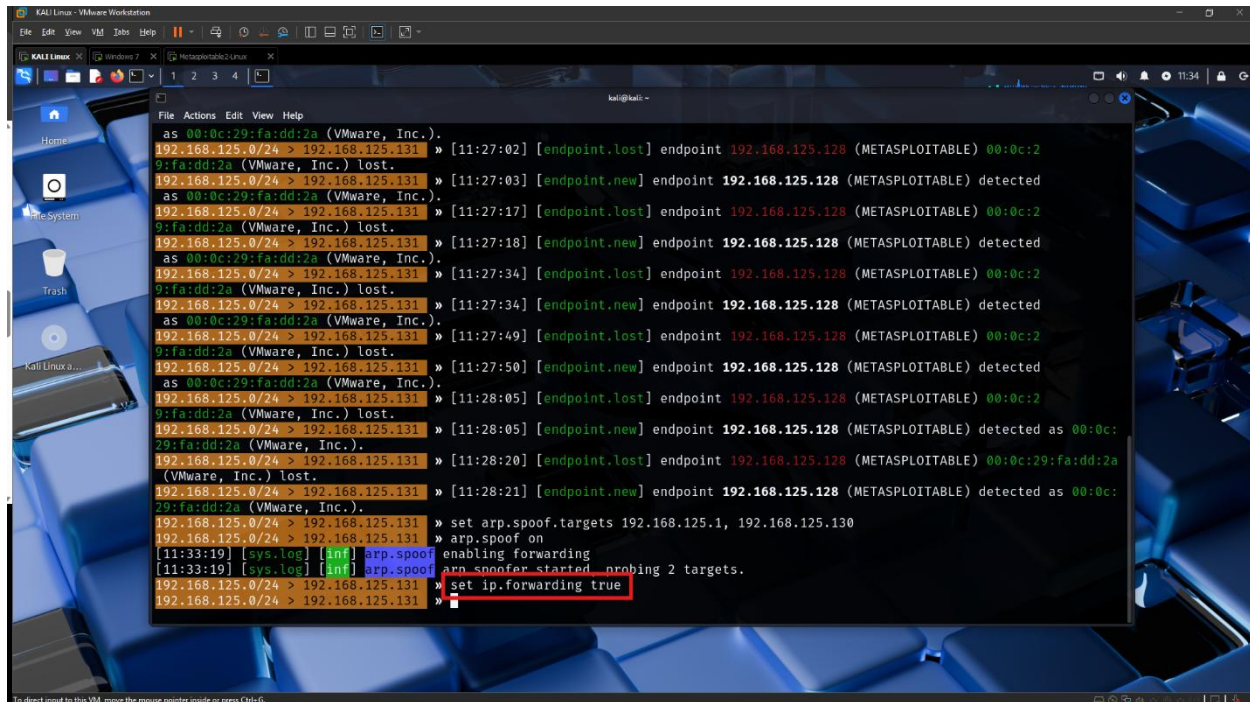


Figure 13:ARP Table on victim machine.

STEP 6: Enable IP forwarding

Use the command “set ip.forwarding true” to enable IP forwarding through your machine. This will enable your machine to forward the packets to their original destination; if disabled, the traffic will stop at your machine, disconnecting the victim from the internet.



The screenshot shows a Kali Linux terminal window with a blue background. The terminal displays a series of network traffic logs, including ARP requests and responses, and the command 'set ip.forwarding true' is highlighted in red. The logs show the following details:

```
as 00:0c:29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:27:02] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:2
9:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:27:03] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected
as 00:0c:29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:27:17] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:2
9:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:27:18] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected
as 00:0c:29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:27:34] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:2
9:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:27:34] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected
as 00:0c:29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:27:49] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:2
9:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:27:50] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected
as 00:0c:29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:28:05] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:2
9:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:28:05] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected as 00:0c:
29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > [11:28:20] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:29:fa:dd:2a
(Vmware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 > [11:28:21] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected as 00:0c:
29:fa:dd:2a (VMware, Inc.).
192.168.125.0/24 > 192.168.125.131 > set arp.spoof.targets 192.168.125.1, 192.168.125.130
192.168.125.0/24 > 192.168.125.131 > arp.spoof on
[11:33:19] [sys.log] [inf] arp.spoof enabling forwarding
[11:33:19] [sys.log] [inf] arp.spoof arp_spoof started probing 2 targets.
192.168.125.0/24 > 192.168.125.131 > set ip.forwarding true
192.168.125.0/24 > 192.168.125.131 >
```

Figure 14: Enabling IP Forward.

STEP 7: Start sniffing the network traffic.

Use the command “net.sniff on” to start sniffing the network traffic. This will capture all the traffic between the targets.

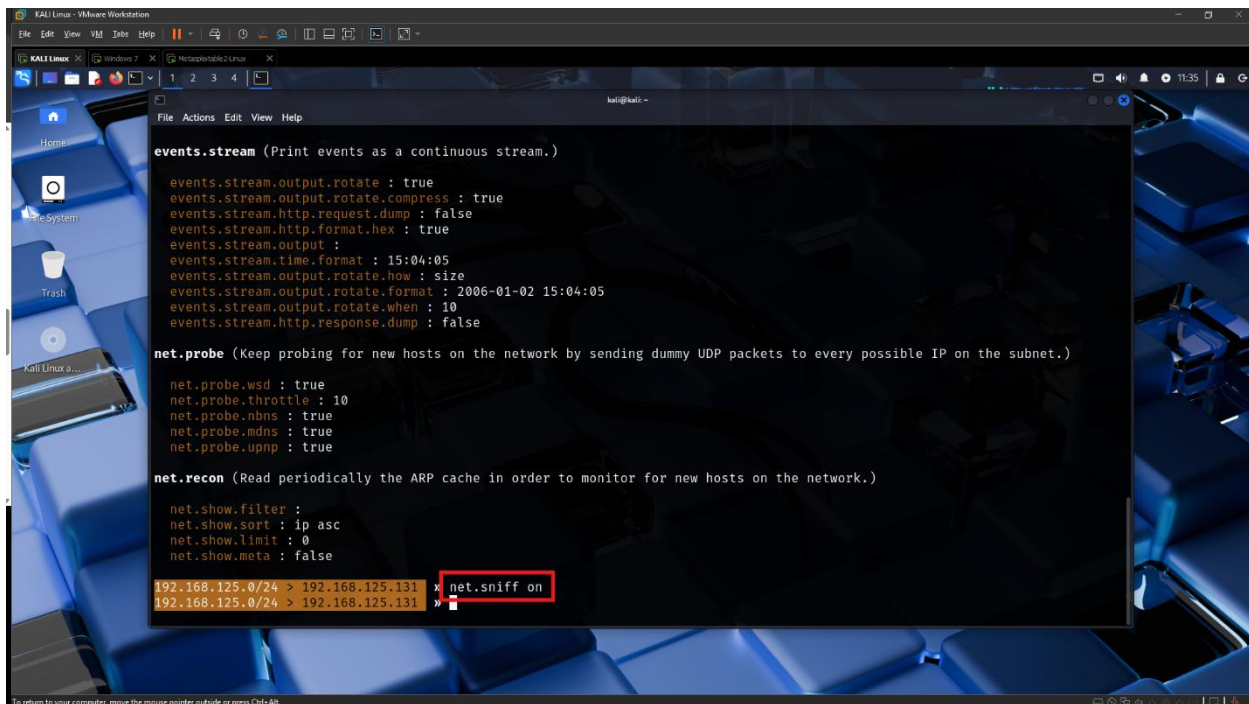


Figure 15: Starting network traffic sniffing.

STEP 8: Opening Metasploitable2 for the vulnerable site.

We will be using Metasploitable2 for the vulnerable site.

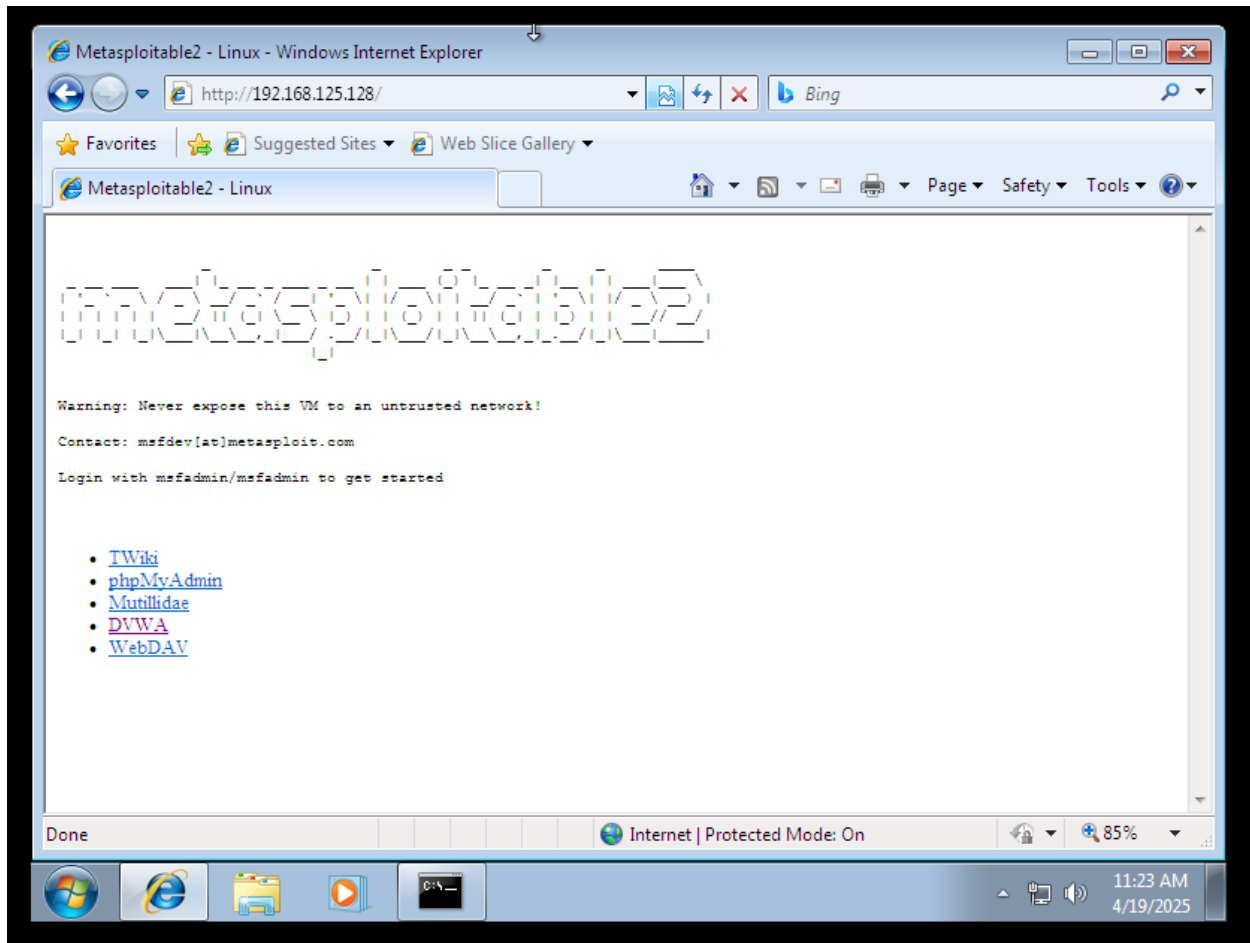


Figure 16: Launching Metasploitable2 as the Target Vulnerable Web Application

STEP 9: Attempting to log in.

In this step, we attempted to log in using different credentials, including the correct one, to test whether the ARP prompt captures only the correct credentials or also the failed ones.



Figure 17: Attempting login with Multiple Credentials (TEST 1).

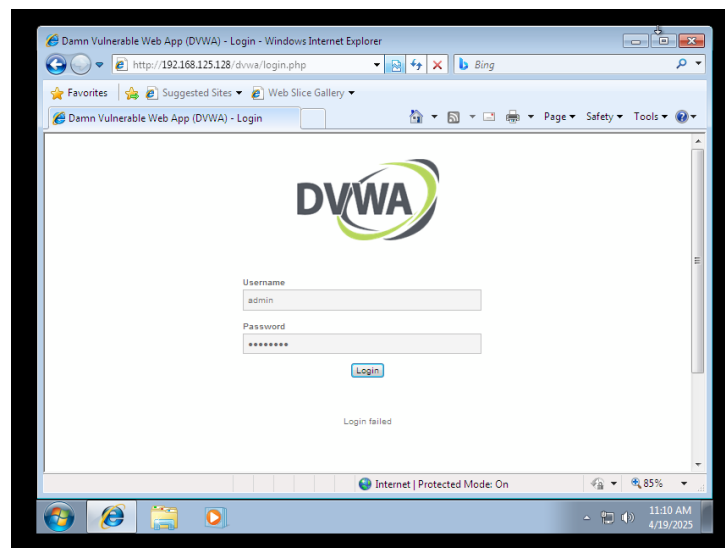


Figure 18: Attempting login with Multiple Credentials (TEST 2).

STEP 10: Capture of the wrong logging credentials.

In both captured credentials, we can see that they both are wrong, as after entering the username and password, it redirects us back to the login page, which is “/dvwa/login.php”.

```

192.168.125.0/24 > 192.168.125.131 » [23:58:25] [net.sniff.http.request] http WIN-80E38AFA8MF POST 192.168.125.128/dvwa/login.php
POST /dvwa/login.php HTTP/1.1
Host: 192.168.125.128
Referer: http://192.168.125.128/dvwa/login.php
Accept-Encoding: gzip, deflate
Cookie: security=high; PHPSESSID=2747d46c150897c8fb57ca14474fd30b
Content-Length: 41
Connection: Keep-Alive
Cache-Control: no-cache
Accept: image/jpeg, application/x-ms-application, image/gif, application/xaml+xml, image/pjpeg, application/x-ms-xbap, */*
Accept-Language: en-US
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/4.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729)
Content-Type: application/x-www-form-urlencoded

username=admin&password=admin&Login=Login

192.168.125.0/24 > 192.168.125.131 » [23:58:25] [net.sniff.http.request] http WIN-80E38AFA8MF GET 192.168.125.128/dvwa/login.php
192.168.125.0/24 > 192.168.125.131 » [23:58:25] [net.sniff.http.response] http METASPLOITABLE:80 302 Found → WIN-80E38AFA8MF (0.8 text/html)
192.168.125.0/24 > 192.168.125.131 » [23:58:25] [net.sniff.http.response] http METASPLOITABLE:80 200 OK → WIN-80E38AFA8MF (1.3 kB text/html; charset=utf-8)
192.168.125.0/24 > 192.168.125.131 » [23:58:26] [net.sniff.http.response] http METASPLOITABLE:80 200 OK → WIN-80E38AFA8MF (1.1 kB text/html; charset=utf-8)
192.168.125.0/24 > 192.168.125.131 » [23:58:43] [endpoint.lost] endpoint 192.168.125.128 (METASPLOITABLE) 00:0c:29:fa:dd:2a (VMware, Inc.) lost.
192.168.125.0/24 > 192.168.125.131 » [23:58:45] [endpoint.new] endpoint 192.168.125.128 (METASPLOITABLE) detected as 00:0c:29:fa:dd:2a (VMware, Inc.).

[23:58:48] [net.sniff.http.request] http WIN-80E38AFA8MF POST 192.168.125.128/dvwa/login.php
POST /dvwa/login.php HTTP/1.1
Host: 192.168.125.128
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate
Content-Length: 44
Connection: Keep-Alive
Accept: image/jpeg, application/x-ms-application, image/gif, application/xaml+xml, image/pjpeg, application/x-ms-xbap, */*
Referer: http://192.168.125.128/dvwa/login.php
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/4.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729)
Accept-Language: en-US
Cache-Control: no-cache
Cookie: security=high; PHPSESSID=2747d46c150897c8fb57ca14474fd30b

username=admin&password=ADMIN123&Login=Login

192.168.125.0/24 > 192.168.125.131 » [23:58:48] [net.sniff.http.request] http WIN-80E38AFA8MF GET 192.168.125.128/dvwa/login.php
192.168.125.0/24 > 192.168.125.131 » [23:58:48] [net.sniff.http.response] http METASPLOITABLE:80 302 Found → WIN-80E38AFA8MF (0.8 text/html)
192.168.125.0/24 > 192.168.125.131 » [23:58:48] [net.sniff.http.response] http METASPLOITABLE:80 200 OK → WIN-80E38AFA8MF (1.3 kB text/html; charset=utf-8)

```

Figure 19: Capture of incorrect login credentials.

STEP 11: Successful capture of the correct logging credential.

After entering the credentials, the website directs us to “/dvwa/index.php” meaning that the credentials are correct.

```

192.168.125.0/24 > 192.168.125.131 » [23:58:59] [net.sniff.http.request] http WIN-80E38AFA8MF POST 192.168.125.128/dvwa/login.php
192.168.125.0/24 > 192.168.125.131 »
POST /dvwa/login.php HTTP/1.1
Host: 192.168.125.128
Cookie: security=high; PHPSESSID=2747d46c150897c8fb57ca14474fd30b
Accept: image/jpeg, application/x-ms-application, image/gif, application/xaml+xml, image/pjpeg, application/x-ms-xbap, */*
Accept-Language: en-US
User-Agent: Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.1; Trident/4.0; SLCC2; .NET CLR 2.0.50727; .NET CLR 3.5.30729; .NET CLR 3.0.30729)
Content-Length: 44
Cache-Control: no-cache
Referer: http://192.168.125.128/dvwa/login.php
Content-Type: application/x-www-form-urlencoded
Accept-Encoding: gzip, deflate
Connection: Keep-Alive

username=admin&password=password6login=Login

192.168.125.0/24 > 192.168.125.131 » [23:58:59] [net.sniff.http.response] http METASPLOITABLE 80 302 Found → WIN-80E38AFA8MF (0 B text/html)
192.168.125.0/24 > 192.168.125.131 » [23:58:59] [net.sniff.http.request] http WIN-80E38AFA8MF GET 192.168.125.128/dvwa/index.php
192.168.125.0/24 > 192.168.125.131 » [23:58:59] [net.sniff.http.response] http METASPLOITABLE:80 200 OK → WIN-80E38AFA8MF (1.1 kB text/html; charset=utf-8)
192.168.125.0/24 > 192.168.125.131 » [23:58:59] [net.sniff.http.response] http METASPLOITABLE:80 200 OK → WIN-80E38AFA8MF (2.6 kB text/html; charset=utf-8)
192.168.125.0/24 > 192.168.125.131 » [23:59:00] [net.sniff.http.request] http WIN-80E38AFA8MF GET 192.168.125.128/dvwa/dvwa/css/main.css

```

Figure 20: Successful capture of correct login credentials.

Phase 6: Post-Exploitation

Analysis of Captured Data:

- Intercepted multiple login attempts.
- Demonstrated ability to capture valid credentials without raising user suspicion.

Impact:

- Full credential compromise.
- Valid credentials could allow unauthorized access to further internal systems (if present).

Cleanup:

- Stopped all Bettercap processes.
- Flushed ARP tables or rebooted affected machines to restore normal state.

Ethical Note:

- The entire procedure was executed under ethical guidelines for educational purposes only.

Phase 7: Reporting & Recommendations

Summary:

- The network was highly vulnerable to ARP spoofing.
- Use of unencrypted login forms exposes critical credentials.
- Lack of ARP inspection or mitigation increases the risk of MitM attacks.

Recommendations:

1. Implement HTTPS with SSL/TLS encryption for all authentication pages.
2. Enable Dynamic ARP Inspection (DAI) on network switches.
3. Use Static ARP entries for critical infrastructure where possible.
4. Deploy Intrusion Detection Systems (IDS) to monitor ARP anomalies.
5. Educate Users on identifying insecure connections.

Table 3 Risk Assessment Table for First Attack

Vulnerability	Risk Level	Potential Impact
ARP spoofing	High	Full credential theft, MitM access
HTTP Login Forms	Critical	Exposure of username and password

3.2. Second Attack

Target Environment: Internal LAN Simulation in GNS3

Phase 1: Pre-Engagement Interactions

Objective:

Simulate an internal threat scenario to evaluate the impact of ARP spoofing in a flat network using legacy communication protocols (e.g., Telnet).

Scope:

Internal IP space: “10.10.10.0/24”

Devices in scope

- Windows 7 VM (“10.10.10.15”)
- Router (R1) (“10.10.10.1”)
- Kali Linux Attacker (“10.10.10.254”)
- Methodology: White-box test (testers have setup-level knowledge)

Rules of Engagement:

- No external network traffic.
- No service disruption beyond the simulated lab.
- Use of known open-source tools: Ettercap, Wireshark, GNS3.

Phase 2: Intelligence Gathering

Technique Used: Passive and active host discovery inside the LAN.

Tool: Ettercap Host Scan

Findings:**Two hosts identified:**

- Router at “10.10.10.1” (likely default gateway)
- Windows 7 PC at “10.10.10.15” (user endpoint)
- MAC addresses recorded for both hosts.

(See Figure 25 Ettercap Host List)

Phase 3: Threat Modeling**Potential Threats Identified:**

- Use of ARP protocol in a switched network makes it vulnerable to spoofing.
- Use of Telnet, a plaintext protocol, poses a critical data exposure risk.
- No authentication or encryption at the ARP layer.

Attack Vector:

Man-in-the-Middle (MITM) via ARP poisoning, leveraging open LAN architecture and legacy protocols.

Assumed Attacker Capabilities:

- Local network access (e.g., compromised machine or malicious insider).
- Ability to run ARP spoofing tools (Ettercap) undetected.

Phase 4: Vulnerability Analysis**Vulnerabilities Identified:**

- No static ARP entries on Windows 7 or Router.
- Telnet service enabled and accepting plaintext credentials.
- Lack of endpoint or switch-level ARP protection mechanisms.

Impact Assessment:

- High: Full compromise of user credentials.
- Medium: Interception and manipulation of LAN traffic.
- Low: Limited to Layer 2 segment.

Phase 5: Exploitation

Step-by-Step Execution:

STEP 1: Setting up a lab environment in GNS3

This network setup is designed to simulate an ARP spoofing attack within a small LAN. It includes a router (10.10.10.1) connected to the internet, a switch, and two virtual machines: a Windows 7 machine (10.10.10.15) as the target, and a Kali Linux machine (10.10.10.254) as the attacker. The Kali machine is used to spoof ARP responses, tricking the victim into thinking the attacker is the gateway. This allows the attacker to intercept, monitor, or manipulate traffic between the Windows machine and the router, demonstrating a man-in-the-middle (MITM) attack scenario.

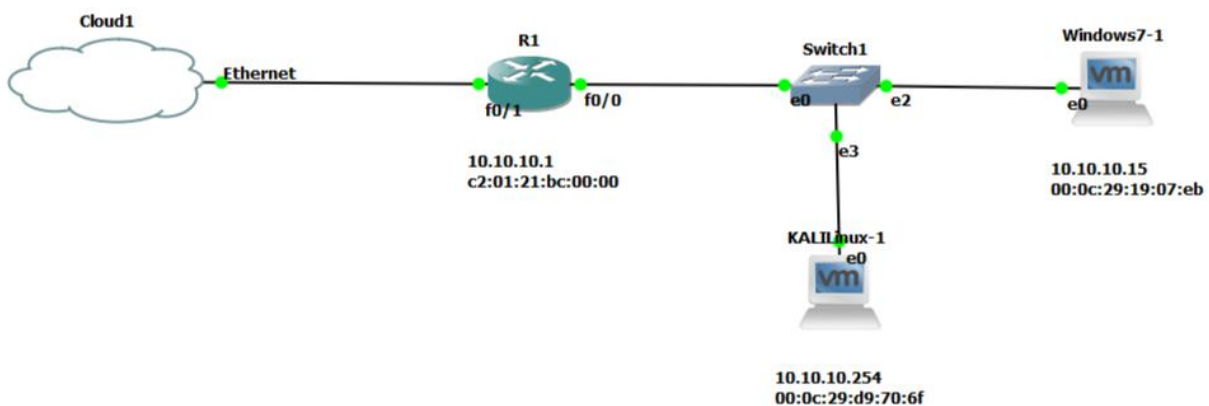


Figure 21: ARP Spoofing Attack Lab Setup

STEP 2: Ettercap configuration

Using Ettercap on the attacker (KALI) machine to perform an ARP poisoning attack. Ettercap tricks the victim's PC and the router into thinking the attacker is the other device. This allows the attacker to sit in the middle of the communication.

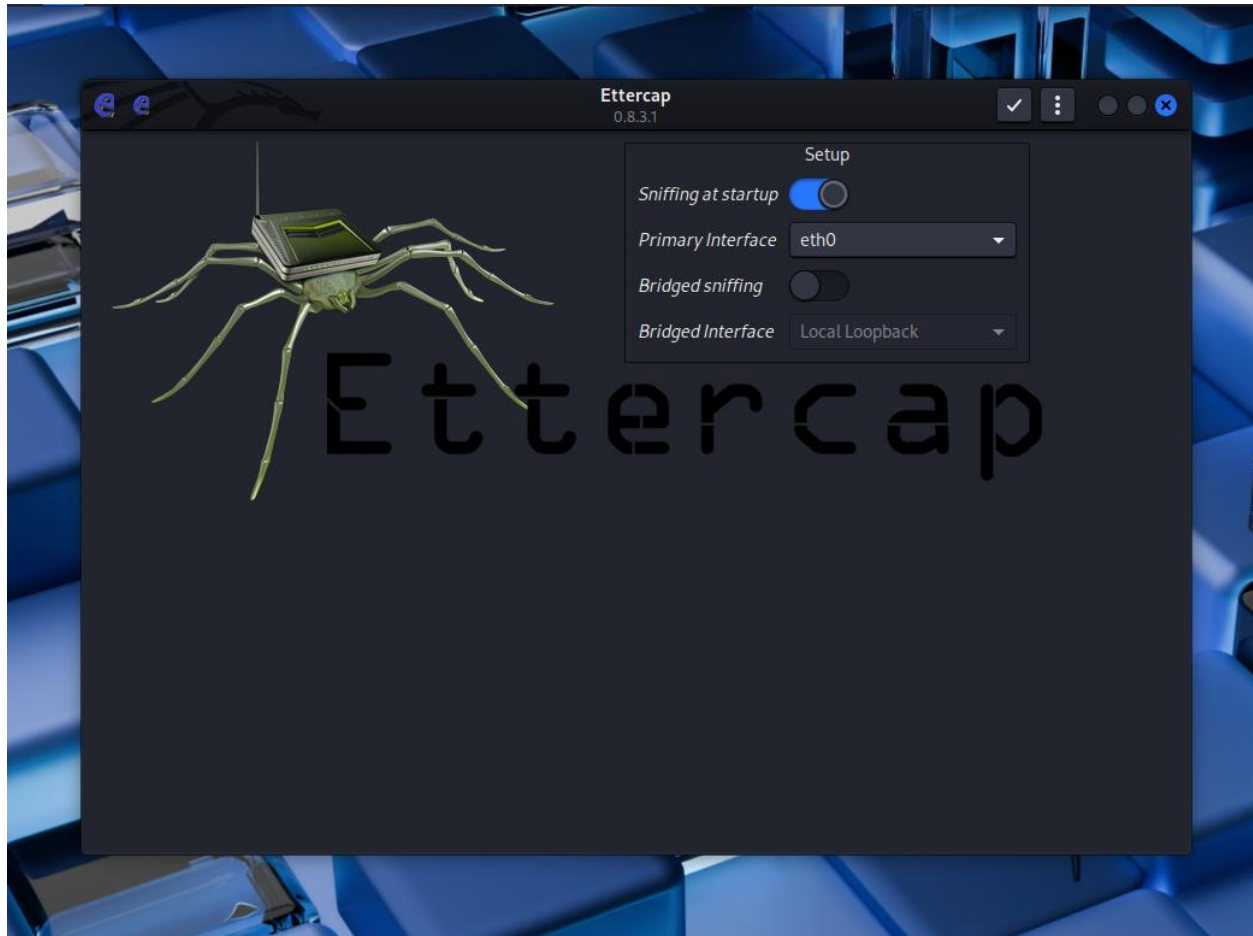


Figure 22: Ettercap configuration

STEP 3: Scanning for the targets.

Assuming the attacker does not know the IP address and MAC address of the devices, first, we'll do a thorough scan using Ettercap's host scan function. We can see it scanned two hosts, i.e., router and Windows, we can see their IP address and MAC address.

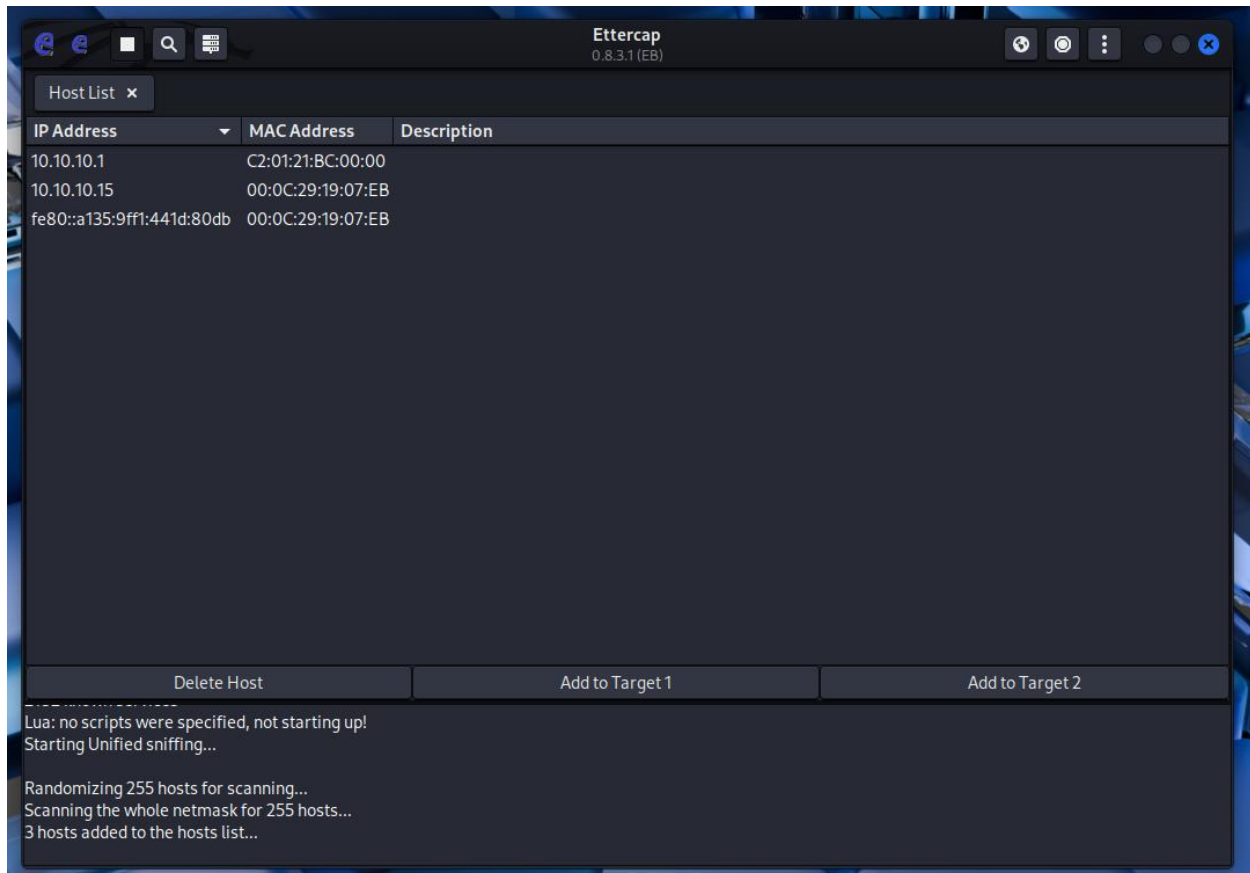


Figure 23: Ettercap Host List

STEP 4: Adding targets.

After scanning the targets, we will then set the targets in Ettercap's target list for attacking them.

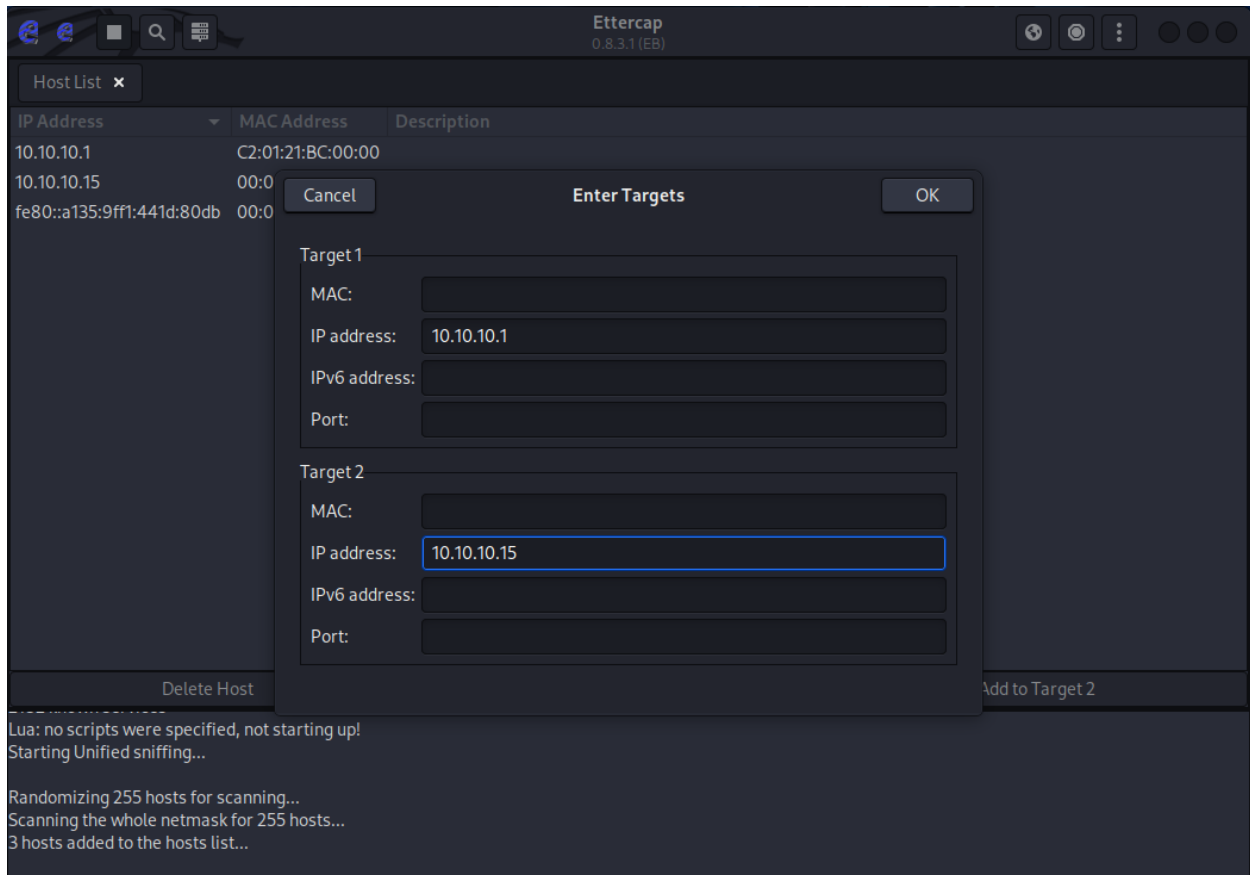


Figure 24: Ettercap Target Selection

STEP 5: Initiating ARP poisoning attack.

Using Ettercap's MITM Attack, we will then start sniffing the target.

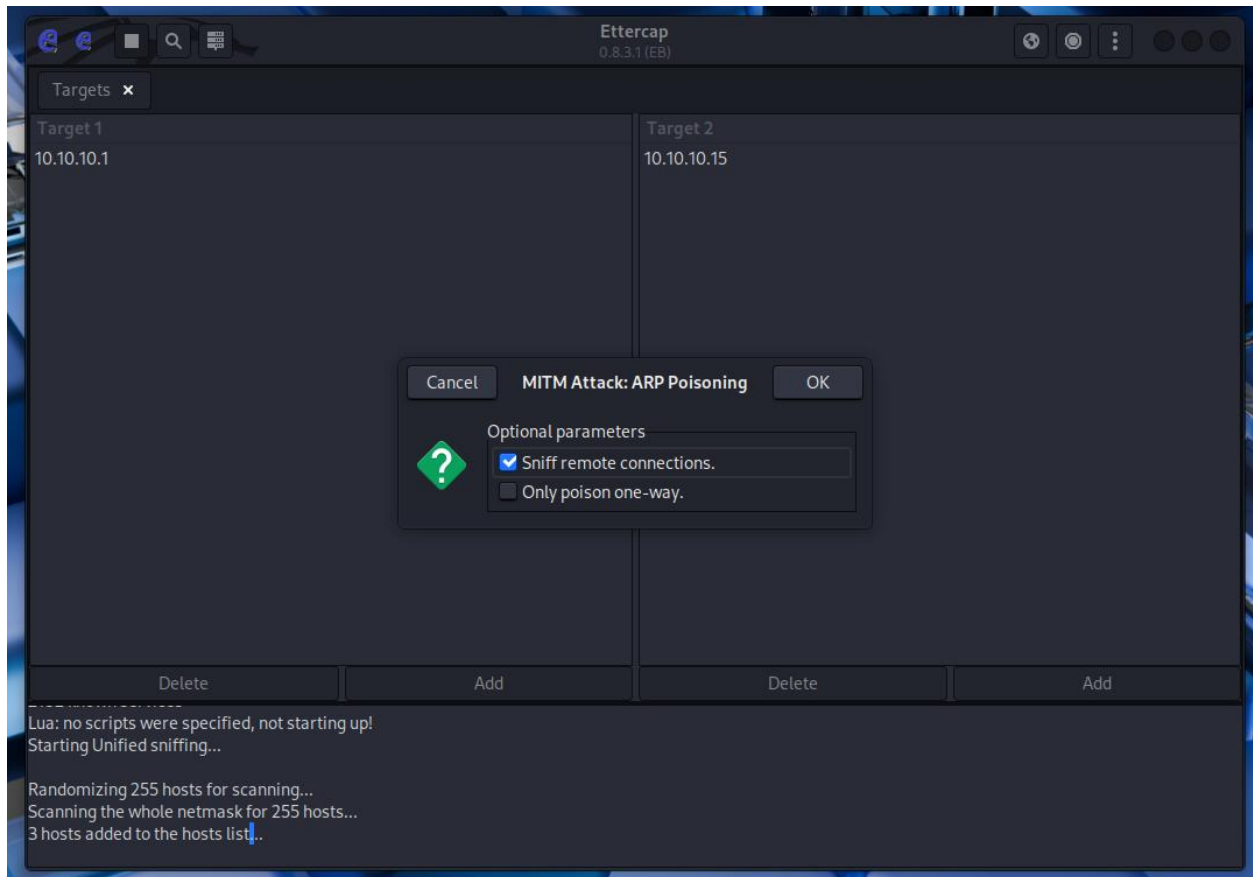
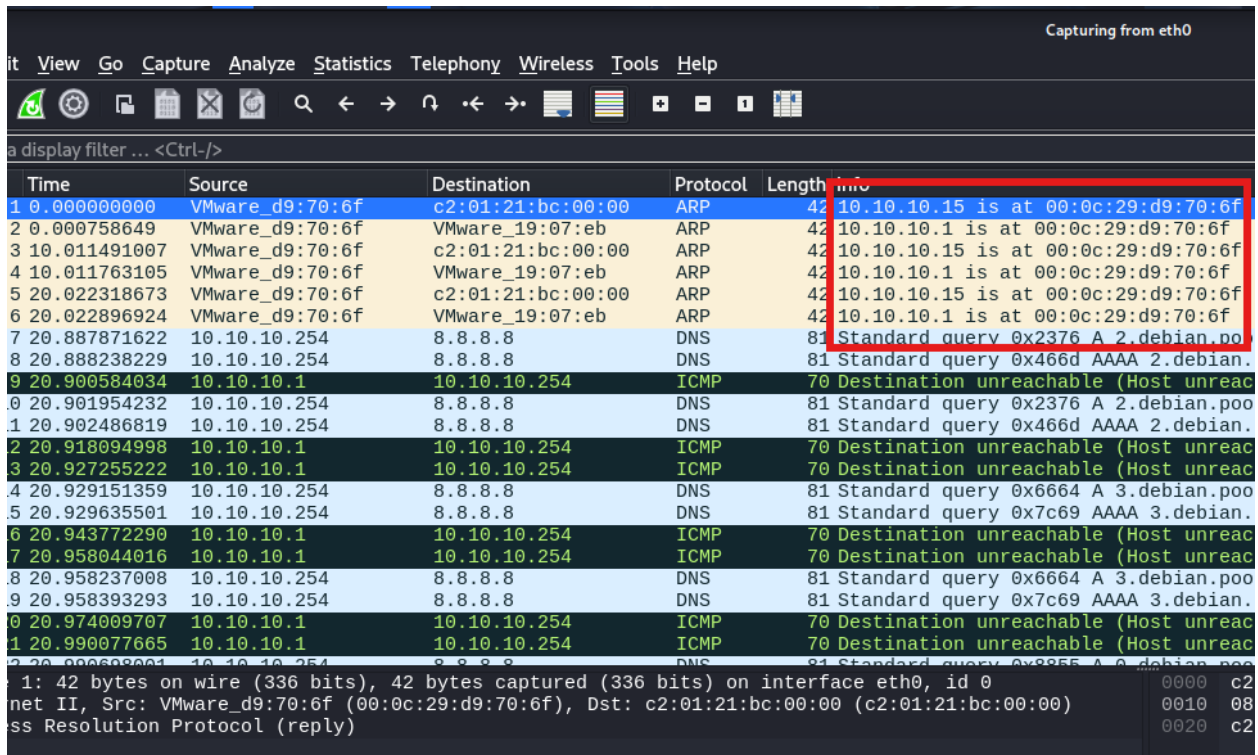


Figure 25: Ettercap Configuration for ARP Poisoning

STEP 6: ARP poisoning successful

We can see that the MAC addresses of both IPs 10.10.10.1 and 10.10.10.15 are the same in the ARP reply, meaning that the MAC address has been successfully cloned.



Time	Source	Destination	Protocol	Length	Info
1 0.000000000	VMware_d9:70:6f	c2:01:21:bc:00:00	ARP	42	10.10.10.15 is at 00:0c:29:d9:70:6f
2 0.000758649	VMware_d9:70:6f	VMware_19:07:eb	ARP	42	10.10.10.1 is at 00:0c:29:d9:70:6f
3 10.011491007	VMware_d9:70:6f	c2:01:21:bc:00:00	ARP	42	10.10.10.15 is at 00:0c:29:d9:70:6f
4 10.011763105	VMware_d9:70:6f	VMware_19:07:eb	ARP	42	10.10.10.1 is at 00:0c:29:d9:70:6f
5 20.022318673	VMware_d9:70:6f	c2:01:21:bc:00:00	ARP	42	10.10.10.15 is at 00:0c:29:d9:70:6f
6 20.022896924	VMware_d9:70:6f	VMware_19:07:eb	ARP	42	10.10.10.1 is at 00:0c:29:d9:70:6f
7 20.887871622	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x2376 A 2.debian.poo
8 20.888238229	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x466d AAAA 2.debian.
9 20.900584034	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
10 20.901954232	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x2376 A 2.debian.poo
11 20.902486819	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x466d AAAA 2.debian.
12 20.918094998	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
13 20.927255222	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
14 20.929151359	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x6664 A 3.debian.poo
15 20.929635501	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x7c69 AAAA 3.debian.
16 20.943772290	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
17 20.958044016	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
18 20.958237008	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x6664 A 3.debian.poo
19 20.958393293	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x7c69 AAAA 3.debian.
20 20.974009707	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
21 20.990077665	10.10.10.1	10.10.10.254	ICMP	70	Destination unreachable (Host unreach)
22 20.990080000	10.10.10.254	8.8.8.8	DNS	81	Standard query 0x2376 A 2.debian.poo

1: 42 bytes on wire (336 bits), 42 bytes captured (336 bits) on interface eth0, id 0
 net II, Src: VMware_d9:70:6f (00:0c:29:d9:70:6f), Dst: c2:01:21:bc:00:00 (c2:01:21:bc:00:00)
 Address Resolution Protocol (reply)

Figure 26: Wireshark Capture Showing ARP Spoofing Traffic

STEP 7: ARP table of the victim PC before and after the ARP poisoning.

We can see that before the attack, the MAC addresses for KALI and Router are different, but after the attack, the MAC address for both KALI and Router are the same.

```

C:\Windows\system32\cmd.exe
Minimum = 4ms, Maximum = 7ms, Average = 5ms
Control-C
^C
C:\Users\ACER>arp -a

Interface: 10.10.10.15 --- 0xb
Internet Address      Physical Address      Type
10.10.10.1            c2-01-21-bc-00-00    dynamic
10.10.10.254          00-0c-29-d9-70-6f    dynamic
10.10.10.255          01-00-5e-00-00-16    static
224.0.0.22            01-00-5e-00-00-16    static
224.0.0.252           01-00-5e-00-00-fc    static

C:\Users\ACER>arp -a

Interface: 10.10.10.15 --- 0xb
Internet Address      Physical Address      Type
10.10.10.1            00-0c-29-d9-70-6f    dynamic
10.10.10.254          00-0c-29-d9-70-6f    dynamic
10.10.10.255          01-00-5e-00-00-16    static
224.0.0.22            01-00-5e-00-00-16    static
224.0.0.252           01-00-5e-00-00-fc    static

C:\Users\ACER>

```

Figure 27: Spoofed Gateway MAC on Window 7

In the router also we can also see that the previous MAC address is different after the attack.

```

R1(config)#do show ip arp
Protocol Address      Age (min)  Hardware Addr  Type   Interface
Internet 10.10.10.1      0          c201.21bc.0000 ARPA    FastEthernet0/0
Internet 10.10.10.15    3          000c.2919.07eb ARPA    FastEthernet0/0
Internet 10.10.10.254    0          000c.29d9.706f ARPA    FastEthernet0/0

R1(config)#do show ip arp
Protocol Address      Age (min)  Hardware Addr  Type   Interface
Internet 10.10.10.1      0          c201.21bc.0000 ARPA    FastEthernet0/0
Internet 10.10.10.15    0          000c.29d9.706f ARPA    FastEthernet0/0
Internet 10.10.10.254    0          000c.29d9.706f ARPA    FastEthernet0/0

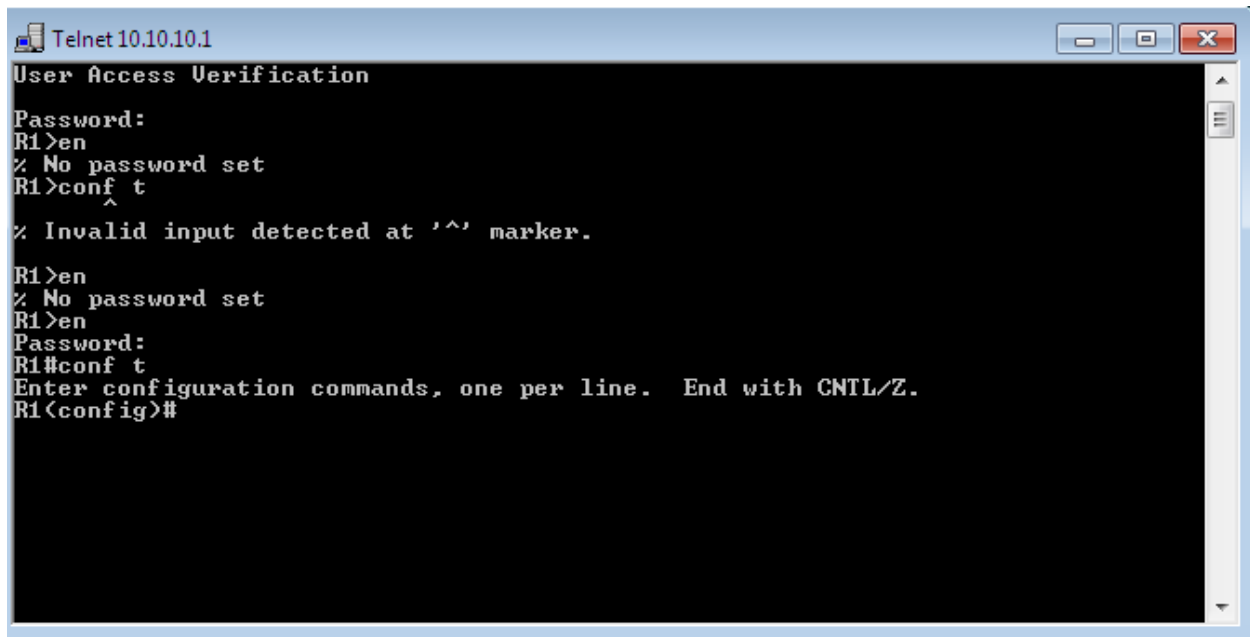
R1(config)#

```

Figure 28: Spoofed Target MAC on Router

STEP 8: Using telnet on the victim's pc to connect to the router.

When the victim connects to the router using telnet, at the IP address 10.10.10.1. After ARP spoofing is successfully executed, the attacker places their machine as a man-in-the-middle between the victim and the router. As a result, the attacker can sniff the unencrypted Telnet traffic.

A screenshot of a Telnet window titled 'Telnet 10.10.10.1'. The window has a blue title bar with standard Windows window controls (minimize, maximize, close). The main area is black with white text. The text shows a sequence of commands and responses: 'User Access Verification', 'Password:', 'R1>en', '% No password set', 'R1>conf t', '^', '% Invalid input detected at '^' marker.', 'R1>en', '% No password set', 'R1>en', 'Password:', 'R1#conf t', 'Enter configuration commands, one per line. End with CNTL/Z.', and 'R1(config)#'.

```
Telnet 10.10.10.1
User Access Verification
Password:
R1>en
% No password set
R1>conf t
^
% Invalid input detected at '^' marker.
R1>en
% No password set
R1>en
Password:
R1#conf t
Enter configuration commands, one per line. End with CNTL/Z.
R1(config)#
```

Figure 29: Telnet Session to Router R1

STEP 9: Telnet Passwords Captured Using ARP Spoofing

By following a telnet packet, we can see the password used by the victim to login into the router via telnet and the password entered to get to the executive mode.

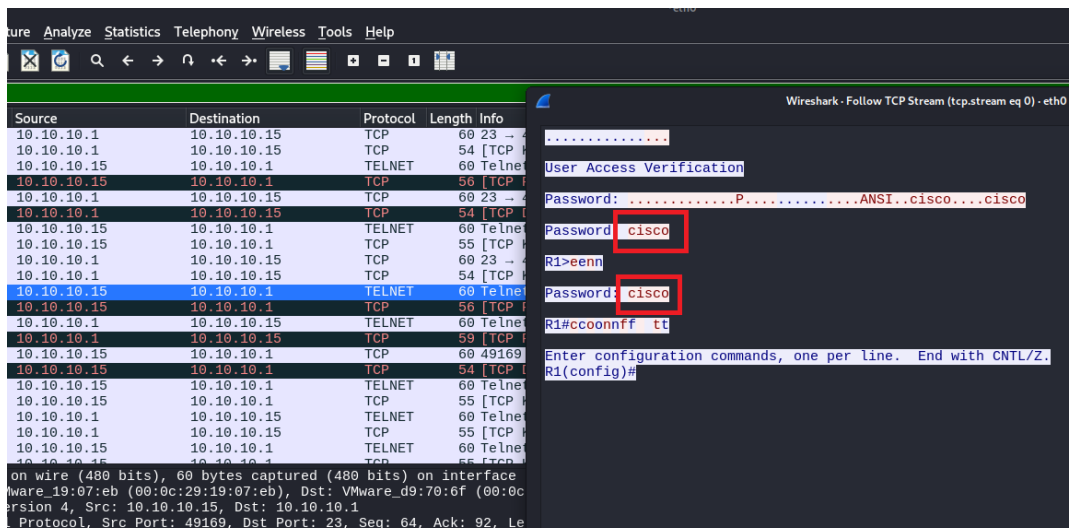


Figure 30: Wireshark Capturing Telnet Password in Cleartext

Phase 6: Post-Exploitation

Access Gained:

- Telnet credentials for router (including privileged mode)
- Potential for further lateral movement from the router device

Data Interception:

- Live Telnet session hijacked
- Plaintext credentials and commands logged

Persistence:

- Not established (attack was limited to demonstration scope)

Lateral Movement Consideration:

Could pivot to other LAN devices if more systems existed or higher access was configured on the router.

Phase 7: Reporting

Summary of Findings:

Table 4 Risk Assessment Table for Second Attack

Issue	Severity	Description
ARP Spoofing Vulnerability	High	No protection against forged ARP replies.
Telnet in Use	Critical	Plaintext transmission of credentials.
Lack of ARP Inspection	Medium	No Layer two security mechanisms in place.
No Endpoint Detection	Medium	Attack Proceeded undetected by Windows 7.

Recommendations:

- Replace Telnet with SSH or secure management protocols.
- Enable Dynamic ARP Inspection (DAI) on switches.
- Implement Static ARP Entries for key infrastructure devices.
- Deploy Host-Based Intrusion Detection Systems (HIDS).
- Conduct Regular Security Awareness Training for network and system administrators.

Supporting Evidence:

- Figure 25: Host Discovery on Ettercap
- Figure 28: Wireshark Capture Showing False ARP Traffic Flooding
- Figure 29: Altered ARP Table on Victim
- Figure 32: Telnet Credentials Captured

4. Mitigation

Address Resolution Protocol (ARP) poisoning represents a sophisticated network attack methodology predominantly utilized for man-in-the-middle (MitM) interception operations. When successfully executed, this technique facilitates the interception and manipulation of network packets across an entire infrastructure. The attack vector operates by flooding falsified ARP messages across a local area network, effectively establishing a corrupt association between the attacker's MAC address and the IP address of a legitimate network device.

While MitM attacks constitute the primary application of ARP poisoning in contemporary threat landscapes, this technique enables multiple additional malicious activities, including:

- Denial of Service (DoS) attacks - Redirecting traffic to non-existent destinations or overwhelming specific network devices
- Session hijacking - Stealing authentication cookies and tokens to take over existing user sessions
- Connection hijacking - Redirecting legitimate connections to malicious servers
- MAC flooding - Overwhelming switch MAC address tables to force broadcasts to all ports
- Packet sniffing - Enabling passive monitoring of unencrypted network traffic
- Data exfiltration - Covertly extracting sensitive data from compromised networks
- DNS spoofing - Redirecting users to fraudulent websites by manipulating DNS responses
- SSL stripping - Downgrading HTTPS connections to HTTP to capture sensitive data
- Network reconnaissance - Mapping network topology and identifying potential targets
- Advanced Persistent Threat (APT) establishment - Creating footholds for long-term network compromise

Operating at Layer 2 of the OSI model, ARP poisoning circumvents numerous traditional security mechanisms designed to protect higher network layers. Modern cybersecurity offers multiple mitigation strategies that organizations can implement against these ARP poisoning vulnerabilities.

A. SOHO scale mitigation using static ARP entries

In a SOHO (Small Office/Home Office) network, one effective and practical method to mitigate ARP spoofing attacks is to use static ARP entries. By manually configuring static ARP entries, critical devices such as routers, computers, and printers are instructed to bind specific IP addresses to fixed MAC addresses, effectively blocking any attempt to alter these mappings through spoofed ARP packets. For instance, assigning a static ARP entry for the default gateway on each client device ensures that malicious ARP replies trying to impersonate the gateway are ignored (Salam, et al., 2014). We have demonstrated how to change the dynamic MAC address into a static MAC address in Linux

First, see the ARP table using the command “arp -a” from which we can observe the default gateway and its MAC address and the interface it's using, which is “enp3s0”.

```
qyz@windows-pc -  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$  
qyz@windows-pc:~$ arp -a  
? (192.168.1.16) at d8:43:ae:29:d7:3b [ether] on enp3s0  
gateway (192.168.1.1) at 80:2d:1a:82:fe:e0 [ether] on enp3s0  
qyz@windows-pc:~$
```

Figure 31: ARP Table Showing IP Addresses

Now, make the MAC address of the default gateway permanent so that the system won't change or expire this ARP mapping automatically. Use the command “sudo ip neigh replace 192.168.1.1 lladdr 80:2d:1a:82:fe:e0 dev enp3s0 nud permanent” to modify the ARP entry of the desired IP with the MAC address you want to assign it and make the ARP entry static and permanent. We can see after the command it says “_gateway (192.168.1.1) at 80:2d:1a:82:fe:e0 [ether] PERM on enp3s0” meaning that the entry is now permanent, and the system won't change it or expire this ARP mapping automatically.



```
root@windows-pc:/home/qvz# sudo ip neigh replace 192.168.1.1 lladdr 80:2d:1a:82:fe:e0 dev enp3s0 nud permanent
root@windows-pc:/home/qvz# arp -a
? (192.168.1.16) at d8:43:ae:29:d7:3b [ether] on enp3s0
_gateway (192.168.1.1) at 80:2d:1a:82:fe:e0 [ether] PERM on enp3s0
root@windows-pc:/home/qvz#
```

Figure 32: Adding a Permanent ARP Entry

B. Enable ARP Anti-Spoofing:

To mitigate ARP spoofing attacks, network administrators can enable ARP anti-spoofing on supported devices. This feature validates ARP packets against trusted bindings and prevents unauthorized ARP responses from altering legitimate mappings (Cisco Systems, Inc., 2020). The following steps outline the configuration process to enable ARP anti-spoofing on a network device:

Step	Command	Description
1	Ip arp inspection vlan 1	Enables Dynamic ARP Inspection (DAI) on VLAN 1.
2	ip dhcp snooping	Enables DHCP Snooping globally on the switch.
3	ip dhcp snooping vlan 1	Enables DHCP Snooping specifically on VLAN 1.

```
Switch(config)#
Switch(config)#
Switch(config)#
Switch(config)#
Switch(config)#ip arp inspection vlan 1
Switch(config)#ip dhcp snooping
Switch(config)#ip dhcp snooping vlan 1
Switch(config)#ip dh
Switch(config)#ip arp inspection vlan 1
```

Figure 33 Anti ARP spoofing commands.

C. Use VPNs and Encryption:

Using VPNs will take devices through a tunnel while connecting to the internet, making sure it makes all communication encrypted and worthless for an ARP spoofing attacker (imperva, 2025). MiTM attacks capture the login credentials that were once transmitted in plain text. SSL/TLS encryption makes it more difficult for the attacker to capture the credentials. They can still capture the credentials, but in their encrypted form, they cannot do anything. We can use HTTPS instead of HTTP, SSH instead of Telnet, FTPS instead of FTP, and other forms of encryption (Grimmick, 2022).

D. Prevention measures using anti-ARP tools.

Multiple tools can be easily downloaded and used for ARP prevention. We have mentioned some and explained the best tools to use for the prevention of ARP poisoning.

Tool	Detection Accuracy	Prevention Capability	Performance Impact	Platform Support	Ease of Deployment
Snort	High	Yes (inline mode)	Moderate	Cross-platform	Requires setup and rule-tuning
Xarp	Moderate	None (purely detection tool)	Low	Windows and linux (abandonware status)	Plug and play GUI.
shARP	Basic	Yes (Defensive and offensive modes.)	Varies by scan mode	Linux only	Requires configuration

Table 5 Comparative table.

After evaluating XArp, Snort and shARP for mitigating ARP poisoning based on their respective official documentation, Snort emerges as the most effective solution.

“Snort is the foremost Open-Source Intrusion Prevention System (IPS) in the world” (Snort, 2025). Its Arp spoof inspector analyses ARP packets to identify layer two inconsistencies such as duplicated MAC addresses and mismatched MAC and IP pairs. When anomalies are detected, Snort can generate alerts and drop offending packets, thereby actively preventing ARP cache poisoning attacks (Cisco System, 2025)

In practical applications, Snort has demonstrated effectiveness in identifying ARP spoofing activities. For instance, during controlled experiments, Snort successfully detected spoofed ARP replies generated by tools like Ettercap, capturing the attacker’s MAC address and alerting administrators to the intrusion (Bijral, et al., 2017).

5. Evaluation

This portion of the report includes the critical evaluation of the mitigating measures given in the mitigation portion of the report.

i. Static ARP Entries

a. Pros

- **Highly effective against basic ARP Spoofing**
Attackers on the local network can simply reroute traffic by delivering fake ARP for important devices when static ARP entries are manually configured.
- **Cost-effective security solutions**
A significant advantage for SOHO settings with tight budgets is the accessibility of free or reasonably priced security products. Small organizations and individuals may use these tools to store important security measures in place without having to spend a lot of money.
- **Ease of Deployment**
In SOHO situations, a lot of basic security protocols are made to be easy to utilize. Changing default passwords on devices, enabling two-factor authentication on online accounts and configuring robust Wi-Fi encryption via a router's interface are usually simple procedures that do not require highly skilled technical personnel.
- **Remote work security**
Remote connections, which are frequently utilized in SOHO installations are protected by mitigation techniques including email encryption, secure remote desktop access and VPNs.

b. Cons

- **Limited technical expertise**
Most SOHO users do not have dedicated IT support which may result in an increase of the risk of misconfigurations during setup.
- **Low quality hardware and software**
Consumer-grade routers and security tools lack advanced features and regular updates.

- Inadequate backup and recovery plans
SOHO devices do not update automatically which makes it difficult to recover data in the event of ransomware or hardware failure.
- High dependence on user behavior
SOHO environments are heavily reliant on user habits and human error which is the major vulnerability.

ii. Enable ARP Anti-Spoofing

a. Pros

- Centralized protection
A more centralized layer of protection against ARP spoofing for all connected clients may be achieved by turning on ARP anti-spoofing on a network device.
- Dynamic prevention
By automatically comparing ARP packets to trusted and known bindings, it may stop malicious changes without requiring explicit endpoint settings.
- Handles a dynamic environment better than a static ARP
Legitimate ARP mappings can frequently be dynamically learned by devices implementing ARP anti-spoofing, eliminating the need for frequent manual updates.
- Options for handling suspicious packets
The network may respond to such assaults in a variety of ways, according to the option to flood or ignore unknown ARP messages.

b. Cons

- Hardware dependency
Only network devices that expressly support ARP anti-spoofing can use this capability. This feature might not be included in many entry-level consumer-grade SOHO routers and switches.
- Configuration complexity
Although the Cisco CLI example appears to be simple, other networking equipment may have a more complicated configuration procedure.

- Potential for false positives
If not properly configured, aggressive ARP anti-spoofing settings may block valid ARP traffic, resulting in connection problems.
- May not protect against attacks originating from compromised devices
ARP anti-spoofing on the central device may not be as effective if a hacked device within the trusted network begins delivering spoof ARP packets.

iii. Use VPNs and Encryption

a. Pros

- Comprehensive data protection
VPNs encrypt all network communication between the client device and the VPN server, rendering the information incomprehensible to attackers who try to capture traffic by ARP spoofing.
- Protects against more than just ARP Spoofing
VPNs guard against various forms of eavesdropping by encrypting communication and hiding the user's IP address.
- Reduces the impact of Man-in-the-Middle-Attacks
Even with ARP spoofing, attackers can effectively intercept traffic, although encryption makes it difficult for them to access private information like login passwords.
- Relatively easy to implement for end users
Encryption is very simple for end users to implement with the help of intuitive VPN clients and web browsers that support HTTPS.

b. Cons

- Performance overhead
Because of the encryption and routing procedures involved, VPNs may degrade internet speed and add some delay.
- Cost of VPN services
Although there are free VPNs, they frequently have restrictions on security speed and data consumption. Subscription fees are typically associated with trustworthy VPN services.

- ARP Spoofing cannot be directly prevented
VPNs and encryption shield data from possible ARP spoofing attacks, but they cannot prevent the attacker from rerouting traffic.
- Endpoint vulnerabilities remain
Despite a VPN, users can still take advantage of flaws on the client devices.

iv. Prevention measures using anti-ARP tools

a. Pros

- Diverse Capabilities Across Tools

The set includes tools with both detection (XArp) and prevention (Snort, shARP) capabilities, offering flexibility for different network environments and security needs.

- Cross-Platform Availability

Combined, the tools cover Windows and Linux platforms, ensuring broader applicability in mixed-OS environments.

- Open Source and Free Options

All tools are freely available or open-source, making them accessible for organizations with limited budgets.

- Real-Time Monitoring and Alerts

Tools like Snort and XArp provide real-time alerts, enabling quick responses to ARP spoofing attempts.

- Customizability and Control

Tools such as shARP allow advanced configuration, supporting both defensive and offensive testing scenarios, which is useful in penetration testing and adaptive defense.

b. Cons

- Inconsistent Prevention Capabilities

Not all tools support active prevention (e.g., XArp is detection-only), limiting their standalone usefulness in fully securing a network.

- Maintenance and Usability Issues

Some tools (e.g., XArp) are outdated or no longer maintained, while others (e.g., Snort and shARP) require technical knowledge and manual configuration, increasing administrative overhead.

- Platform Limitations

Some tools are platform-specific (e.g., shARP is Linux-only), reducing their usability in diverse network infrastructures.

- Performance Trade-offs

Tools with prevention capabilities (like Snort) may introduce moderate performance impact, especially when deployed in inline mode.

- Complex Integration in Enterprise Environments

Deploying multiple tools in parallel may result in redundant alerts, compatibility issues, or higher complexity in network management and monitoring.

In summary, every mitigation strategy has unique advantages for SOHO settings and the most effective protection against ARP spoofing and associated man-in-the-middle assaults is frequently a layered strategy that combines static ARP entries for important devices with ARP anti-spoofing on compatible hardware, anti-ARP tools for active monitoring, and the consistent use of VPNs and encryption for securing sensitive communications. This multi-faceted strategy greatly enhances network resilience and ensures ongoing protection even in evolving threat landscapes.

6. Conclusion

Lastly, ARP spoofing-based Man-in-the-Middle (MitM) attacks provide a persistent and significant risk to local networks. Attackers can intercept and manipulate data between communicating devices, frequently undetected, by taking advantage of the ARP protocol's intrinsic lack of authentication. An attacker can easily compromise sensitive information, including login passwords or personal data, in an unsecured network environment, as demonstrated by the investigation of ARP spoofing techniques and tools like Bettercap, Ettercap and Wireshark. This report demonstrates the importance of strong internal security controls and shows how even minor protocol flaws can have disastrous results.

This report highlights the need for a tiered security strategy by thoroughly examining mitigating strategies, which range from implementing static ARP entries which can help lock down known device mapping, preventing unauthorized changes. Enabling ARP anti-spoofing features and using anti-ARP spoofing tools, which provide continuous monitoring and real-time alerts about suspicious activities. Beyond local network controls, deploying VPNs and strong encryption protocols ensures that even if attackers intercept traffic, the data remains protected from unauthorized access or tampering.

Ultimately, this project has demonstrated the importance of layered and proactive monitoring, ongoing vigilance, and well-structured protection measures in lowering the danger of such assaults has grown because of this experience. To guarantee the resilience of their systems against more complex MitM attacks, it shows the larger requirement for companies and developers to use preventative techniques and maintain a solid security posture. This experience has deepened the understanding of both the technical aspects and strategic responses required to counter MitM attacks and highlights the ongoing responsibility of organizations and developers to maintain a strong and adaptable security posture.

7. References

afteracademy, 2020. *afteracademy*. [Online]

Available at: <https://afteracademy.com/blog/what-is-arp-and-how-does-it-work/>

[Accessed 28 March 2025].

Barath, 2021. *Metasploit Basics for Beginners – Exploiting Windows XP (MS08–067) with Metasploit (Kali Linux) – Part 1*. [Online]

Available at: <https://www.getastra.com/blog/security-audit/how-to-hack-windows-xp-using-metasploit-kali-linux-ms08067/>

[Accessed 2 May 2025].

Bettercap, 2025. *Introduction*. [Online]

Available at: <https://www.bettercap.org/intro/>

[Accessed 7 May 2025].

Bijral, R. K., Gupta, A. & Sharma, L., 2017. *Study of Vulnerabilities of ARP Spoofing and its detection using SNORT*. [Online]

Available at:

https://www.researchgate.net/publication/343529869_Study_of_Vulnerabilities_of_ARP_Spoofing_and_its_detection_using_SNORT

[Accessed 10 May 2025].

Britannica, 2025. *Stuxnet*. [Online]

Available at: <https://www.britannica.com/technology/Stuxnet>

[Accessed 2 May 2025].

Buxton, O., 2022. *Stuxnet: What Is It & How Does It Work?*. [Online]

Available at: <https://www.avast.com/c-stuxnet>

[Accessed 2 May 2025].

Cisco System, 2025. *Chapter: Snort 3 Inspectors*. [Online]

Available at: <https://www.cisco.com/c/en/us/td/docs/security/secure-firewall/snort3-inspectors/snort-3-inspector-reference/inspectors.html>

[Accessed 10 May 2025].

Cisco Systems, Inc., 2020. *Security Configuration, Cisco Catalyst PON Series Switches*. San Jose: Cisco Systems, Inc..

CVE Details, 1999. *CVE Details*. [Online]

Available at: <https://www.cvedetails.com/cve/CVE-1999-0667>

[Accessed 29 March 2025].

elprocus, 2024. *elprocus*. [Online]

Available at: <http://elprocus.com/address-resolution-protocol/>

[Accessed 28 March 2025].

Ettercap Project, 2001. *Ettercap*. [Online]

Available at: <https://www.ettercap-project.org>

[Accessed 29 March 2025].

Ettercap, 2025. *Ettercap Home Page*. [Online]

Available at: <https://www.ettercap-project.org/index.html>

[Accessed 3 May 2025].

Fortinet, 2025. *Fortinet*. [Online]

Available at: <https://www.fortinet.com/resources/cyberglossary/what-is-arp>

[Accessed 28 March 2025].

Geeksforgeeks, 2024. *Geeksforgeeks*. [Online]

Available at: <https://www.geeksforgeeks.org/what-is-an-eavesdropping-attack/>

[Accessed 29 March 2025].

Genians, 2023. *Genians*. [Online]

Available at: <https://www.genians.com/learn-more/insights/secure-your-network-by-leveraging-address-resolution-protocol-arp-security/>

[Accessed 29 March 2025].

GoDaddy Content Team, 2024. *GoDaddy*. [Online]

Available at: <https://www.godaddy.com/resources/es/seguridad/que-es-el-arp-spoofing-y-como-protegerse-ante-este-ataque>

[Accessed 29 March 2025].

Grimmick, R., 2022. *ARP Poisoning: What it is & How to Prevent ARP Spoofing Attacks*.

[Online]

Available at: <https://www.varonis.com/blog/arp-poisoning>

[Accessed 20 April 2025].

Grimmick, R., 2022. *Varonis*. [Online]

Available at: <https://www.varonis.com/blog/arp-poisoning>

[Accessed 29 March 2025].

Hanna, K. T., 2024. *Wireshark*. [Online]

Available at: <https://www.techtarget.com/whatis/definition/Wireshark>

[Accessed 4 May 2025].

Hijazi, S. & Obaidat, M. . S., 2018 . Address resolution protocol spoofing attacks and security approaches: A survey. *Security and Privacy*, Volume 1(2), p. 1–9.

imperva, 2025. *imperva*. [Online]

Available at: <https://www.imperva.com/learn/application-security/man-in-the-middle-attack-mitm/>

[Accessed 29 March 2025].

ipcisco, 2024. *ipcisco*. [Online]

Available at: <https://ipcisco.com/lesson/address-resolution-protocol-arp/>
[Accessed 28 March 2025].

Jongsma, C., 2008. *Networkworld*. [Online]

Available at: <https://www.networkworld.com/article/806726/lan-wan-surprise-arp-attack-draws-attention.html>
[Accessed 29 March 2025].

Kerner, S. M., 2012. *Metasploit Goes Phishing*. [Online]

Available at: <https://www.esecurityplanet.com/networks/metasploit-goes-phishing/>
[Accessed 3 May 2025].

Lake, J., 2023. *Comparitech*. [Online]

Available at: <https://www.comparitech.com/blog/information-security/arp-poisoning-spoofing-detect-prevent/>
[Accessed 29 March 2025].

Landau, A., 1990s. *Github*. [Online]

Available at: <https://github.com/alandau/arpspoof>
[Accessed 29 March 2025].

Markova, V., 2025. *Cloudns*. [Online]

Available at: https://www.cloudns.net/blog/arp-address-resolution-protocol-why-is-it-important/#Why_is_it_important
[Accessed 29 March 2025].

M. & E., 2023. *Stuxnet*. [Online]

Available at: <https://www.ebsco.com/research-starters/computer-science/stuxnet>
[Accessed 3 May 2025].

Miller, J., 2025. *BitLyft*. [Online]

Available at: <https://www.bitlyft.com/resources/common-network-security-threats-and-how-to-mitigate-them>
[Accessed 27 March 2025].

Nidecki, T. A., 2025. *invicti*. [Online]

Available at: <https://www.invicti.com/learn/mitm-arp-spoofing/>
[Accessed 29 March 2025].

Plummer, D. C., 2025. *datatracker*. [Online]

Available at: <https://datatracker.ietf.org/doc/html/rfc826>
[Accessed 28 March 2025].

Ramachandran, V. & Nandi, . S., 2005. *Detecting ARP Spoofing: An Active Technique*.
Guwahati, Sukumar Nandi.

rfwireless, 2024. *rfwireless*. [Online]

Available at: <https://www.rfwireless-world.com/Articles/ARP-attack-types-MAC-flooding-and-ARP-Spoofing.html>

[Accessed 28 March 2025].

Salam, A. M., Elkilani, W. & Amin, K. M., 2014. International Journal of Advanced Computer Science and Applications. *IJACSA*, 5(1), pp. 105,106.

sentinelone, 2024. *SentinelOne*. [Online]

Available at: <https://www.sentinelone.com/cybersecurity-101/threat-intelligence/arp-spoofing/>

[Accessed 27 March 2025].

SentinelOne, 2024. *SentinelOne*. [Online]

Available at: <https://www.sentinelone.com/cybersecurity-101/threat-intelligence/arp-spoofing/>

[Accessed 28 March 2025].

Snort, 2025. *What is Snort?*. [Online]

Available at: <https://snort.org/>

[Accessed 5 May 2025].

Sreedeeep, 2025. *The Stuxnet Story: How a Digital Worm Changed Cyber Warfare Forever*. [Online]

Available at: <https://journal.hexmos.com/stuxnet/>

[Accessed 3 May 2025].

Termanini, D. R., 2020. Hacking DNA genes—The real nightmare. In: D. R. Termanini, ed. *Storing Digital Binary Data in Cellular DNA*. Cambridge, MA: Academic Press, p. 79–95.

TheTechArtist, 2024. *TheTechArtist*. [Online]

Available at: https://thetechartist.com/arp-and-its-function/#Importance_for_Network_Communication

[Accessed 29 March 2025].

Threat Intelligence, 2021. *A Brief Guide of Metasploit*. [Online]

Available at: <https://www.threatintelligence.com/blog/metasploit>

[Accessed 3 May 2025].

Thurston, R., 2008. *Ethical hacking site falls victim to hackers*. [Online]

Available at: <https://www.itnews.com.au/news/ethical-hacking-site-falls-victim-to-hackers-113233>

[Accessed 3 May 2025].

Zydyk, M., 2023. *TechTarget*. [Online]

Available at: <https://www.techtarget.com/searchnetworking/definition/Address-Resolution-Protocol-ARP>

[Accessed 28 March 2025].

8. Appendix

Importance of ARP

Address Resolution Protocol (ARP) plays a crucial role in network communication because it bridges the gap between logical addressing (IP) and physical addressing (MAC) in a network (Markova, 2025). Without the help of ARP even if the devices are on the same local network, they still wouldn't know how to reach each other (Markova, 2025). Some importance of ARP are as follows:

- **Translates IP address to MAC address:** At the Data Link Layer MAC addresses are used by the devices to communicate with each other while IP addresses are used by the applications. Arp dynamically maps IP addresses and MAC addresses making sure that the data reaches the destination (TheTechArtist, 2024).
- **Maintains ARP Tables Automatically:** Unlike manual configurations, ARP builds and updates its cache in real-time. When a device needs another's MAC address, it broadcasts an ARP request, and the correct host replies, updating the table instantly (Fortinet, 2025).
- **Enables Efficient Local Communication:** Before sending data, a device checks its ARP cache. If the MAC isn't there, ARP quickly resolves it, preventing delays. Without ARP, every transmission would fail, like knowing a name but not a phone number (TheTechArtist, 2024).
- **Prevents Network Failures:** ARP prevents IP conflicts by detecting duplicate addresses on the network. When two devices claim the same IP, ARP identifies the mismatch through MAC address verification. This early detection stops communication errors before they can disrupt network operations (Markova, 2025).